IronVision AI

Human-approved AI for the NIST Risk Management Framework

Whitepaper · formerly AegisRMF

Version 1.1 · October 2026
Derived from the code base, migrations, API specification and project reports.
Labels used: **MOCKED** (simulated capability) · **REQUIRES HUMAN VERIFICATION** · **SME REVIEW REQUIRED**.
Demonstration content is synthetic. IronVision AI is not FedRAMP-authorized and holds no ATO.

Contents

1 Executive summary 4
1.1 Problem statement 4
2 Core value and differentiators 6
3 Personas, roles and separation of duties 7
3.1 Separation of duties 7
3.2 Real organizations vs. sandboxes 7
4 RMF lifecycle coverage (NIST SP 800-37 Rev. 2)
5 Screen-by-screen guide 11
5.1 Access 11
5.2 Start 12
5.3 Step 1 – Prepare 15
5.4 Step 2 – Categorize 15
5.5 Step 3 – Select 16
5.6 Step 4 – Implement 18
5.7 Step 5 – Assess 23
5.8 Step 6 – Authorize 26
5.9 Step 7 – Monitor 28
5.10 Tools and administration 29
6 AI components 31
6.1 Inventory of AI features 31
6.2 Provider architecture 32
6.3 Status, health and usage 32
7 Reference content 34
7.1 CNSSI 1253 baseline numbers (selected = 'X' or '+') 34
8 Evidence and data integrity 36
9 eMASS workbooks 37
9.1 Test Result (TR) workbook 37
9.2 Hardware/Software (HW/SW) list 37
9.3 Import Center and Manage imported data 38
10 Technical architecture 40
10.1 API design 40
10.2 Multi-tenancy 41
11 Security and compliance posture 42
12 Deployment and portability 43
13 Use cases and walkthroughs 44
13.1 New system to ATO (FIPS 199) 44
13.2 National Security System (CNSSI 1253) 44
13.3 Continuous monitoring 44
13.4 eMASS round trip 44

13.5 Policy gap analysis 44
13.6 Inventory reconciliation 45
13.7 Demo and sales sandbox 45
14 Limitations, known gaps and roadmap 46
15 Glossary 47
A API endpoint summary (appendix) 48

1 Executive summary

IronVision AI (formerly AegisRMF) is a web application for the NIST Risk Management Framework (RMF). It covers all seven steps of NIST SP 800-37 Rev. 2 for a portfolio of systems, from preparation and categorization through continuous monitoring. It brings together the records that are usually spread across spreadsheets, SharePoint folders, scanner exports and eMASS: systems, roles, categorization, baselines and overlays, control implementations, evidence, findings, POA&Ms, assessments, authorization decisions and the audit trail.

The product rests on four commitments:

- **Human-approved AI.** AI drafts, ranks and explains. It never decides. Every AI output is schema-validated, quotes and references are checked against the source, and a human must approve before anything changes a compliance record. With no AI provider configured, every feature still works with deterministic analysis.
- **Evidence integrity.** Every artifact is stored content-addressed by SHA-256, with provenance, freshness, version history and a hash-chained, append-only audit trail.
- **eMASS-faithful workbooks.** Test Result and Hardware/Software workbooks are imported and written back into the user's own eMASS templates. Only permitted cells change, macros are never executed, and every export comes with a validation report.
- **Portability.** Standard components only (React/TypeScript, FastAPI, PostgreSQL, S3-compatible storage, OIDC), deployable with Docker Compose. AI providers and storage back-ends are chosen through environment values, with no code change.

This paper describes what the software does today. It is derived from the code base, database migrations, API specification and project reports. Capabilities that are simulated are labelled **MOCKED**. Results that could not be verified in the development environment are labelled **REQUIRES HUMAN VERIFICATION**. Interpretations of authoritative documents that need a subject-matter expert are labelled **SME REVIEW REQUIRED**.

> **NOTE**
> IronVision AI is not FedRAMP-authorized, holds no ATO and has not been assessed for IL4–IL6 or CUI. The demonstration environment contains synthetic data only. Nothing in this document claims FIPS 140-3 validation or CAC/PIV conformance.

1.1 Problem statement

Getting and keeping an Authority to Operate (ATO) is labour-intensive. The RMF itself is sound; the burden comes from the tooling around it:

- **ISSOs** keep control narratives, evidence folders and STIG/ACAS results consistent by hand. They re-type the same facts into the SSP, the Test Result workbook, the POA&M and the hardware/software list.
- **Security Control Assessors (SCAs)** must judge evidence that is stale, unattributed or impossible to trace back to a specific file, scan or policy paragraph.
- **Authorizing Officials (AOs)** sign risk decisions based on packages whose provenance is hard to check, with little visibility into what changed since the last review.

- **ISSMs and leadership** lack a live, cross-system view of authorization expirations, overdue POA&Ms, CAT I findings and stale evidence.
- **National Security Systems** add CNSSI 1253 categorization (separate C/I/A impact levels), NSS baselines, overlays and parameter values. Teams usually apply these from PDF tables by hand.

Generic GRC tools either ignore these DoD/IC specifics or bolt on unverifiable AI. IronVision AI models the RMF tasks directly, keeps every artifact traceable, and uses AI only where its output can be checked.

2 Core value and differentiators

Differentiator	What it means in practice	Where it is enforced
Human-approved AI	AI produces drafts, suggestions, rankings and explanations. Approval gates are locked on and cannot be disabled.	AIService (schema + quote validation), review engine, Admin AI settings ('human approval: always on (locked)')
Grounded output	Policy quotes must be exact substrings of the uploaded text. Evidence references must point to real records. Fabricated items are dropped and counted.	policy_profile.verify_quote, TR analysis and inventory validators
Deterministic fallback	With no AI provider, or when AI output fails validation, the deterministic result stands and is labelled.	Every AI call site; the AI status panel shows 'Deterministic analysis (no AI)'
Evidence integrity	SHA-256 content addressing, integrity re-verification, version history, freshness windows, retention with legal hold.	Storage service, evidence_versions, retention job, Evidence Ledger
Tamper-evident audit	Every state change writes a hash-chained audit_events row. A database trigger makes the table append-only.	audit service, migration 0001 trigger, chain verification in the Audit Log
Separation of duties	No self-approval, SCA independence, AO-only decisions, Platform Admin without decision rights.	rbac.py assertion, sod.py, review engine
eMASS-faithful workbooks	Import and write back the user's own TR and HW/SW templates. Only permitted ranges change; the VBA project and signature parts stay byte-identical.	services/tr, services/inventory/hwsw, validation reports
CNSSI 1253 depth	Per-objective C/I/A, Appendix D baselines with page citations, official overlays, parameter value adoption with undo and conflict detection.	cnssi1253.py, cnssi_params.py, overlays.py
Portability	Docker Compose, PostgreSQL, any S3 API, OIDC, pluggable AI. The env file is parsed as data and validated by check_env.	deploy/, scripts/check_env.py, docs/PORTABILITY.md

3 Personas, roles and separation of duties

Authorization is role-based and scoped to an organization or to a single system. Roles come only from IronVision AI's own RBAC, never from identity-provider claims. The permission matrix is defined in code (backend/app/security/rbac.py) and shown read-only on the Admin page and in 'Help: who can do what'.

Role	Typical person	Key permissions (abridged)
System Owner	Mission/system owner	system.write, evidence.submit, poam.manage, system.register, ingest.upload, implementation.write
ISSO	Information System Security Officer	System Owner rights plus finding.map, source.manage, evidence.verify, audit.read, emass.queue
ISSM	Information System Security Manager	portfolio.read, system.roles.manage, content.apply, finding.map, emass.queue, admin.health.read
SCA	Security Control Assessor	assessment.perform (the only role that sets assessment status / TR compliance status), evidence.verify
AO	Authorizing Official	authorization.decide, risk.accept, portfolio.read
DevSecOps	Engineer / pipeline owner	evidence.submit, ingest.upload, source.manage
Leadership Viewer	Executive	portfolio.read (read-only)
Privacy Official	Senior agency privacy official	privacy.review (approve or return PTAs and privacy determinations)
Platform Admin	Tool administrator	Users, content loading, AI test, jobs, eMASS connector settings. **No** AO, SCA or risk-acceptance rights (asserted at start-up).

3.1 Separation of duties

- A requester can never approve their own request (reviews engine).
- Only the SCA sets an assessment result. The SCA must be independent of the implementer.
- Only the AO issues ATO, ATO with conditions, IATT or DATO decisions and accepts risk. The ISSO cannot accept risk.
- Test Results: a row edited or prepared by one person must be approved by a different real user (shared helper services/sod.py). The same applies to inventory changes (accept → approve).
- Every denial is audited as authz.denied. Every mutating API route declares a permission dependency, and an automated test fails if any route lacks one.

3.2 Real organizations vs. sandboxes

Self-service sandboxes (Explore Demo or self sign-up) can enable **persona mode**. One person can then act as ISSO, SCA, AO and the other roles through the 'Acting as' switcher in the header. Actions run as synthetic persona identities, so the role rules stay enforced. Every audit event also records the real operator.

- In a **real organization**, approval must come from a different real user. Switching persona does not count, and the UI shows the action as locked with the reason.

- In a **sandbox**, a different persona of the same real user may approve. The event is labelled **'Sandbox: same person'** in the audit log, on the row and in export history.
- Persona approvals are labelled 'simulated signature – not CAC/PIV · sandbox persona'.
- Persona mode is refused (403) on non-sandbox tenants. Client-supplied flags such as is_sandbox or X-Sandbox are ignored.

> **NOTE**
> One human holding all personas is **not** acceptable separation of duties for production. Production tenants keep strict real-identity separation of duties.

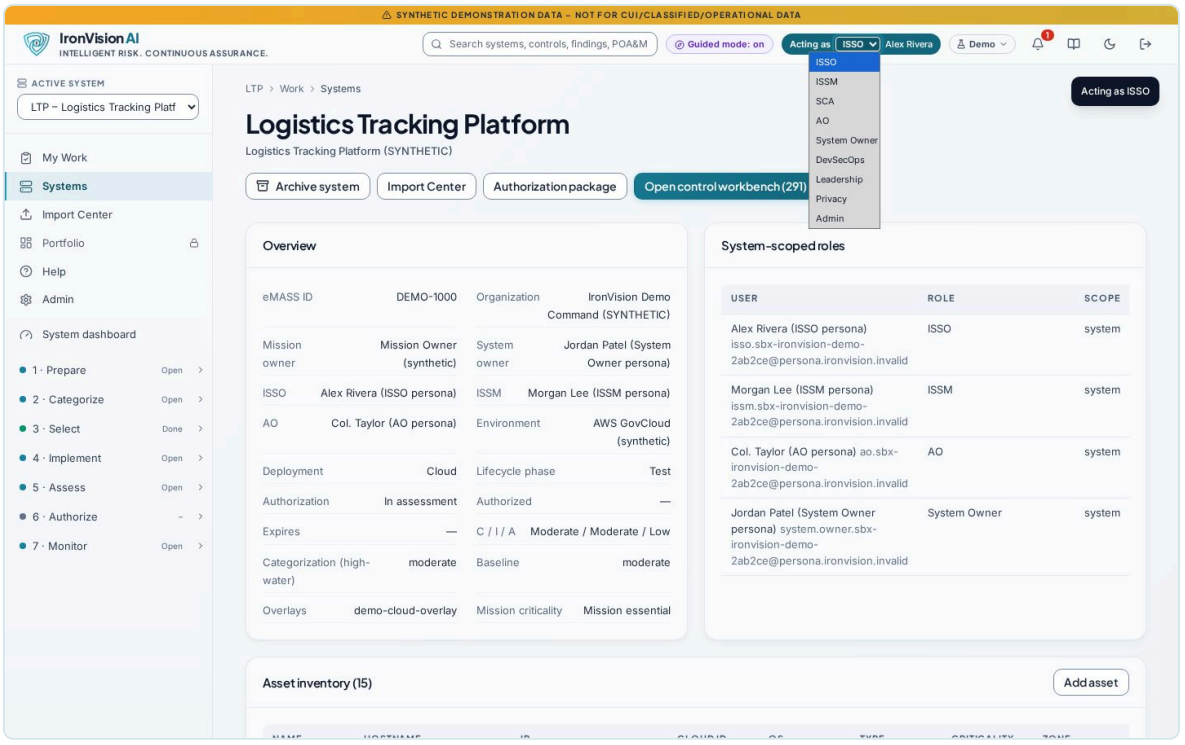


Figure: Sandbox persona switcher ('Acting as') in the header

4 RMF lifecycle coverage (NIST SP 800-37 Rev. 2)

The system dashboard, the RMF navigation and the per-system stepper compute a status for each of the seven steps from live data. A status is never typed in by hand. Each step reports one of **not started**, **needs attention** or **complete**, with the criteria behind it, a progress counter and the single next action with a deep link. Every import and analysis ends with 'Completed – next: ...' pointing to the step that uses the result.

Step	What IronVision AI does	'Complete' when
1 Prepare	Key roles (AO, ISSM, ISSO, System Owner, SCA, Privacy Official ...) assigned per system, with role history; system boundary and description.	All required key roles are filled
2 Categorize	Information types from the NIST SP 800-60 Vol. 2 Rev. 1 catalog (168 types); FIPS 199 high-water mark or CNSSI 1253 per-objective C/I/A; NSS determination (Yes/No/Unsure); PII Yes/No (Yes adds the Privacy Overlay); AO approval with revision history and re-approval on change.	Categorization approved and no required field missing
3 Select	SP 800-53B baseline (FIPS) or CNSSI 1253 Appendix D trigraph union (NSS); overlays; tailoring in/out with justification; organization-defined parameters (ODPs); CNSSI parameter adoption; Privacy Overlay prompt.	Baseline applied, no unresolved reconciliation or tailoring issues
4 Implement	Control Workbench: implementation status, statements (with optional AI draft), inheritance, evidence, policy mappings, CCIs.	Every assigned control has an implementation status
5 Assess	SCA assessments per control, eMASS Test Results workbook, STIG/ACAS findings, Mapping Review.	Every assigned control is assessed
6 Authorize	Authorization package, ISSM endorsement, AO decision (ATO / ATO w/ conditions / IATT / DATO), POA&Ms, risk acceptance, eMASS sync.	A current authorization decision exists
7 Monitor	Rule-based monitoring: CISA KEV, CAT I, overdue POA&Ms, stale evidence; scheduled jobs; evidence freshness; Evidence Ledger.	Monitoring configured and nothing needs attention

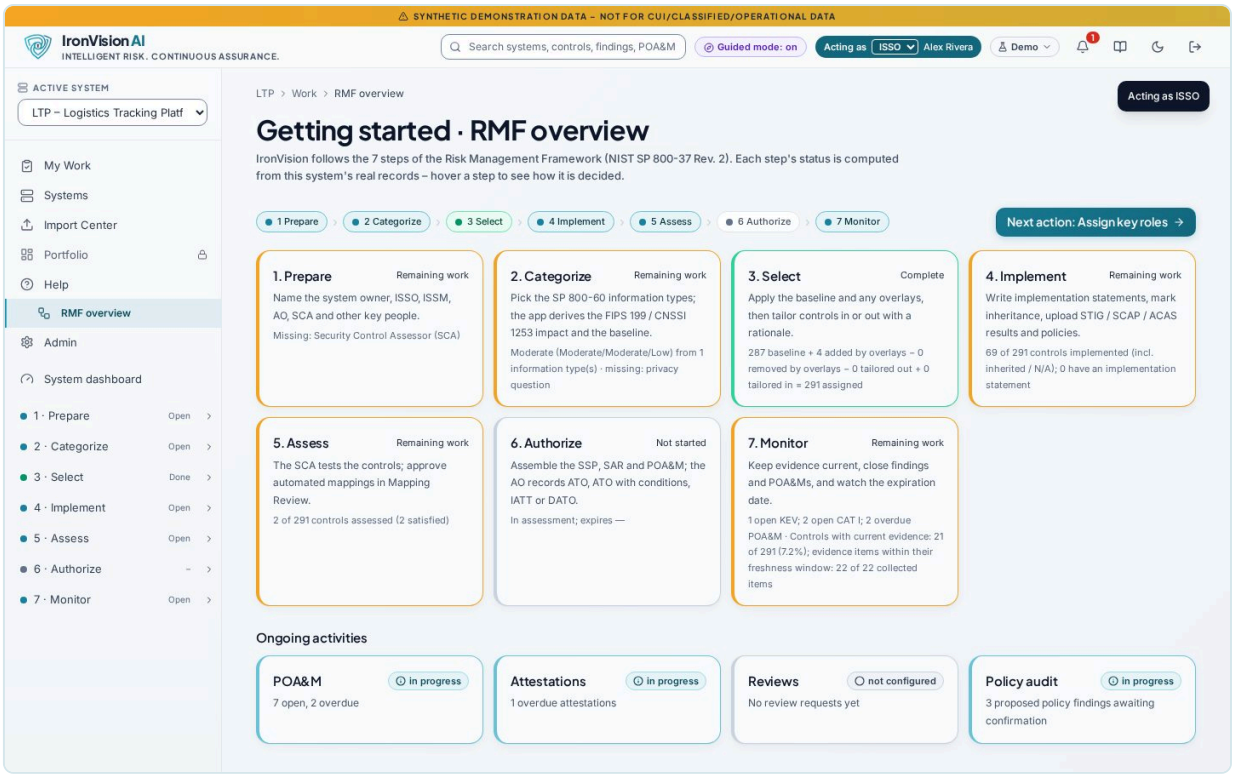


Figure: RMF overview with live step statuses and the next action

5 Screen-by-screen guide

Each entry describes one page in the application: its purpose, who uses it, the key actions, what it produces and the guardrails that apply. Routes are given for orientation. Navigation: My Work, Systems, Import Center, Help and Admin, then the seven RMF steps of the selected system (1 Prepare … 7 Monitor). Clicking a step opens its main page; the chevron lists the step's pages. Every older route still works and opens the same page inside its step. Both themes meet WCAG 2.2 AA contrast (text 4.5:1, controls, borders and focus rings 3:1, readable disabled labels) and button, tab and chip labels never wrap – toolbars move whole buttons to the next line or into a 'More' menu on phones, and wide tables scroll instead of squeezing columns.

5.1 Access

Login, demo and sign-up (/login)

Purpose	Sign in with the configured provider (local password in development and demo, OIDC/Keycloak in deployed environments), open the shared synthetic demo, or create a private sandbox.
Used by	Everyone
Key actions	Sign in; 'Explore demo' (one-click, rate-limited, audited); 'Create account' (when sign-up is enabled); open the public whitepaper.
Outputs	A server-side session (idle timeout 30 min, absolute 12 h, rotating refresh tokens).
Guardrails	Lockout after 5 failures for 15 minutes. Sign-up bot checks (trap field and minimum time-to-submit), 12+ character passwords. Sign-up is off in production. New sandboxes start empty.

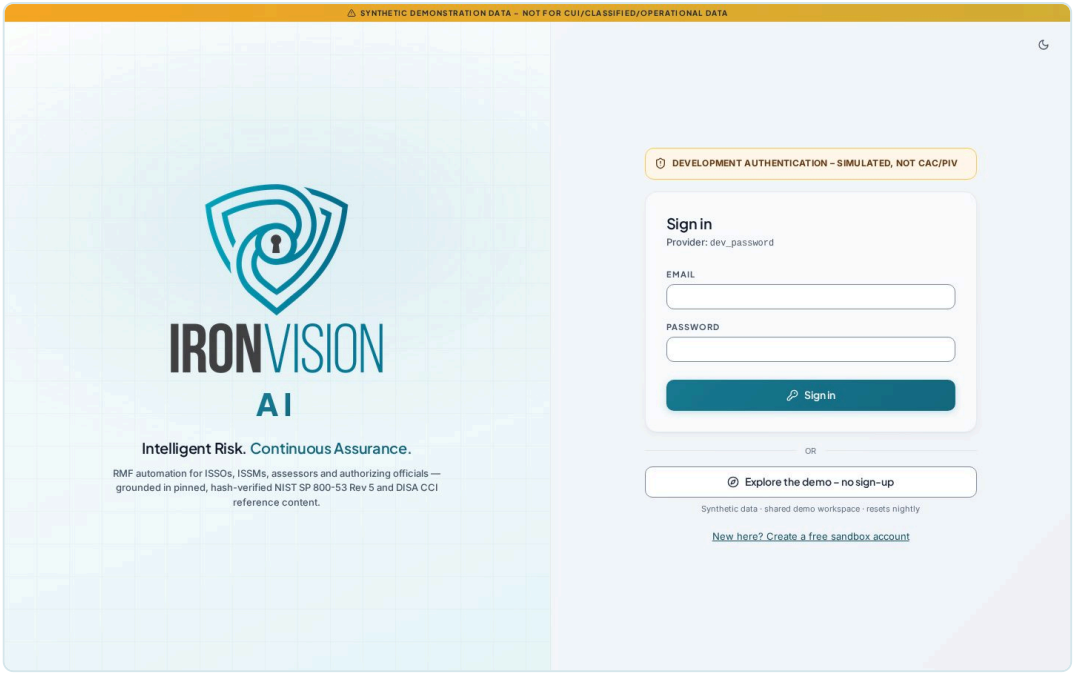


Figure: Login page

5.2 Start

My Work (/my-work)

Purpose	Role-based home: what is waiting for the current role – statements and suggestions (ISSO), assessment requests and retests (SCA), strategy, package and review approvals (ISSM), authorization decisions (AO).
Used by	All roles
Key actions	Open an item; it opens the record in its RMF step.
Outputs	None (read-only aggregation of existing queues).
Guardrails	Shows only items the role may act on; approvals stay with the approving role (separation of duties, SCA independence, AO authority).

System dashboard (/dashboard)

Purpose	One page per system: seven step cards with live status, 'Continue where you left off', pending approvals and the next action.
Used by	All roles
Key actions	Open a step; continue the last record.
Outputs	None (read-only).
Guardrails	Statuses are computed, never edited.

Guided Mode (header toggle)

Purpose	Per user and off by default; offered once at first login. Adds to every step its purpose, why it matters, what you need, who does it and what comes next.
Used by	All roles
Key actions	Switch on or off at any time.
Outputs	None.
Guardrails	Same data, permissions and workflow rules as the streamlined mode – only explanations are added.

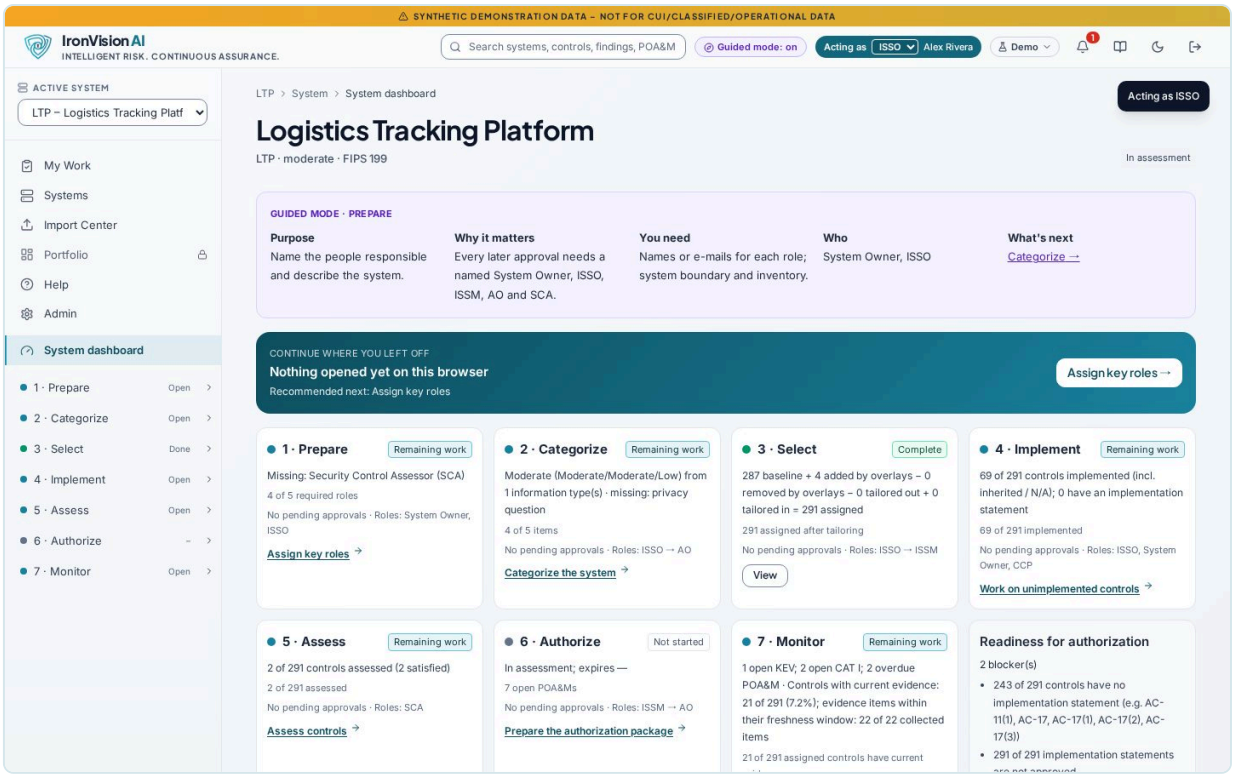


Figure: System dashboard with the RMF navigation

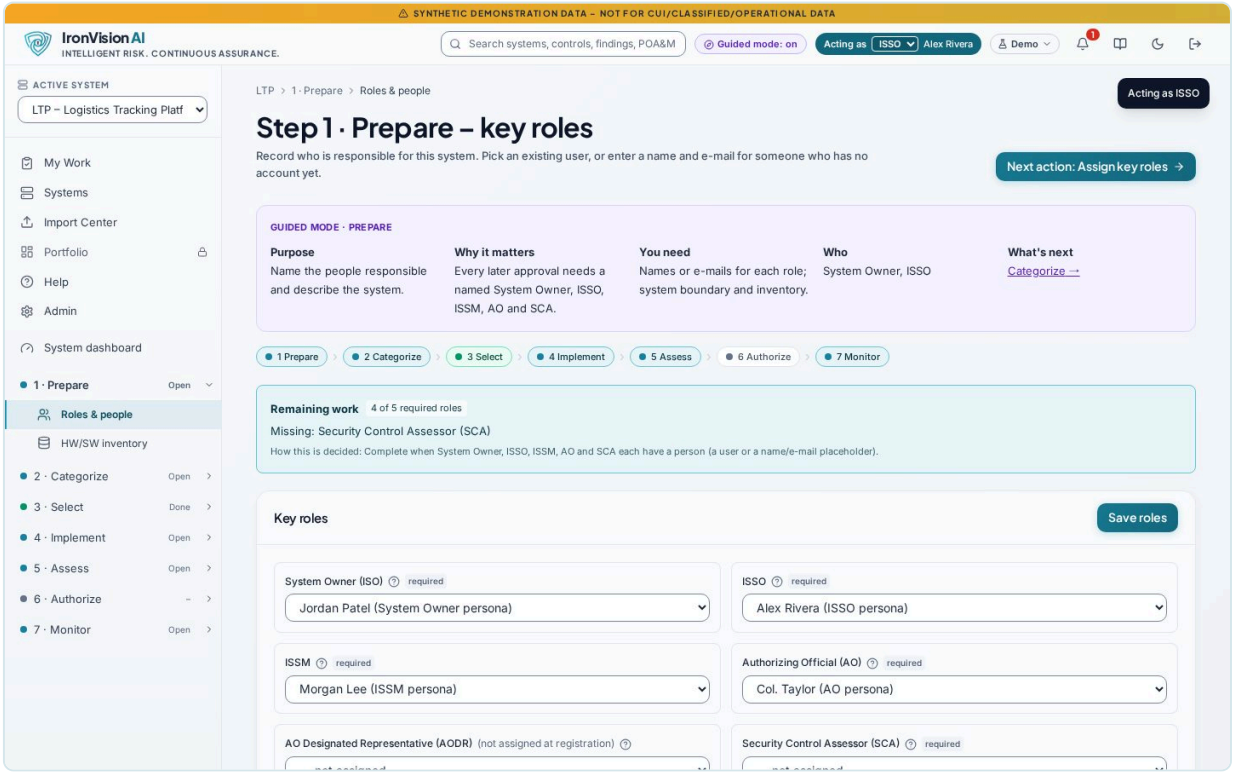


Figure: Guided Mode on (Prepare – key roles)

Getting started – RMF overview (/rmf-workflow)

Purpose	Live seven-step overview for the active system, with criteria and the next action.
Used by	All roles
Key actions	Follow the next-action link; open any step.
Outputs	Step statuses, progress counters.
Guardrails	Statuses are computed, never edited.

Systems (/systems, /systems/new, /systems/:id)

Purpose	Register systems, maintain boundary, description, operating environment, DoD Cloud SRG impact level, assets and system-scoped role assignments.
Used by	ISSO, ISSM, System Owner
Key actions	Register (role keys validated server-side); edit; assign and revoke roles (audited); archive and restore (audited).
Outputs	System record, role history.
Guardrails	Impact-level rules: IL picker only for cloud deployment models; IL6 only for NSS + classified = Yes (422 otherwise). Archived systems are hidden but restorable.

Portfolio / Leadership (/portfolio)

Purpose	Cross-system posture: ATO expirations, open POA&Ms, CAT I, KEV exposure, evidence freshness, trends, 'waiting on you'.
Used by	ISSM, AO, Leadership Viewer
Key actions	Drill into a system or POA&M.
Outputs	Portfolio cards, operational priority scores with a breakdown that sums.
Guardrails	Requires portfolio.read.

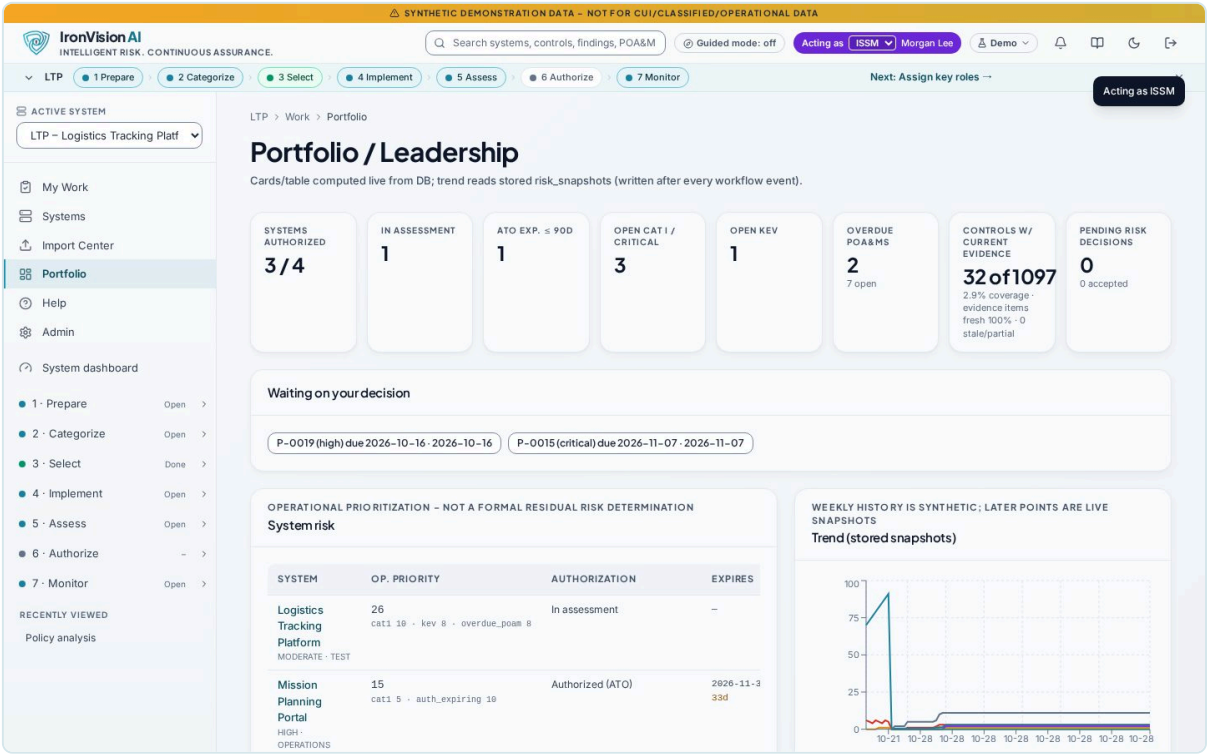


Figure: Portfolio / Leadership dashboard

5.3 Step 1 – Prepare

Key roles (/rmf/prepare)

Purpose	Assign the RMF key roles for the system and record the people who hold them.
Used by	ISSM, ISSO
Key actions	Assign or replace a role holder; view history.
Outputs	Role assignments used by the review engine.
Guardrails	Role changes need system.roles.manage and are audited.

5.4 Step 2 – Categorize

Categorization (/rmf/categorize)

Purpose	Select information types and compute the security category. Record the NSS determination, framework (FIPS 199 or CNSSI 1253) and one Yes/No answer: 'Does this system contain PII?'.
Used by	ISSO (prepares), AO (approves)
Key actions	Pick SP 800-60 information types with provisional impacts and adjust them with justification; answer 'Is this a National Security System?' (Yes/No/Unsure); answer the PII question (Yes or No); submit for approval.
Outputs	FIPS 199: per-objective high-water mark and overall category. CNSSI 1253: separate C/I/A trigraph (e.g. M-H-L) and no overall value. A versioned categorization revision. PII = Yes adds the Privacy Overlay at once (FIPS 199: SP 800-53B privacy baseline; CNSSI 1253: the Privacy Overlay variant for the impact level) and the note under the question shows how many controls it adds.
Guardrails	Approval needs authorization.decide. A change to an approved categorization creates a pending re-approval and the approved values stay in force. Changing the PII answer later asks for confirmation naming the controls affected; removal never deletes implementation statements or evidence. The answer and the overlay change are audited. The earlier Privacy Threshold Analysis questionnaire is retired; existing PTA records stay read-only.

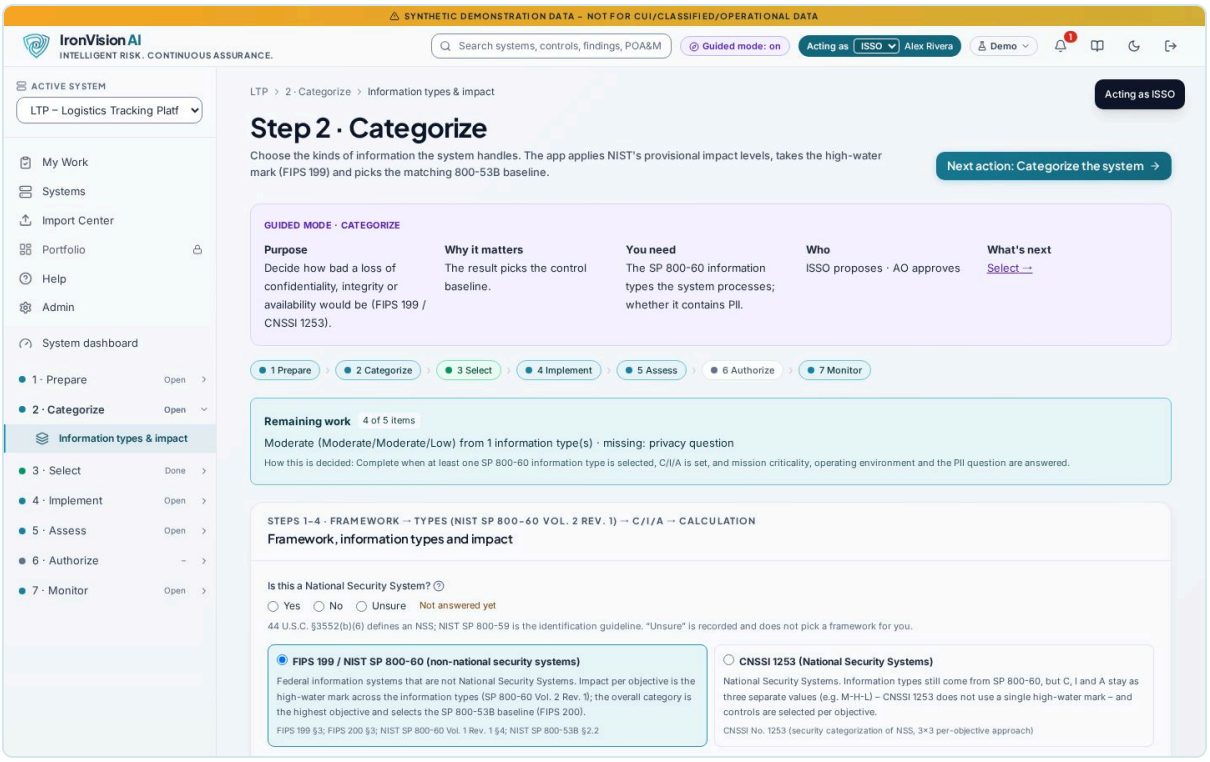


Figure: Categorize: information types, NSS determination and framework

5.5 Step 3 – Select

Baseline, overlays and tailoring (/rmf/select)

Purpose	Apply and reconcile the control baseline, overlays, tailoring decisions and organization-defined parameters.
Used by	ISSO, ISSM
Key actions	Apply the SP 800-53B baseline or the CNSSI 1253 trigraph baseline; accept or decline a baseline proposal after re-categorization; apply overlays (official CNSSI overlays for NSS, agency overlays as metadata); tailor controls in or out with justification; compare and adopt CNSSI parameter values; respond to the Privacy Overlay prompt.
Outputs	Control assignments with selection provenance (for example 'Selected by CNSSI 1253 Table D-3 (C=M), p. D-22 (PDF p. 43)'), tailoring record, ODP values with source.
Guardrails	Proposals apply only on Accept. Tailored-out controls stay out, and controls that already have statements, evidence or assessment work are kept as tailored in, never dropped. Overlays: CNSSI overlays only on NSS; the Classified overlay requires an explicit 'classified = Yes'; restricted overlays show 'Unavailable – pending validation'. Parameter adoption returns 409 with the conflicts before it overwrites a differing value, and can be undone.

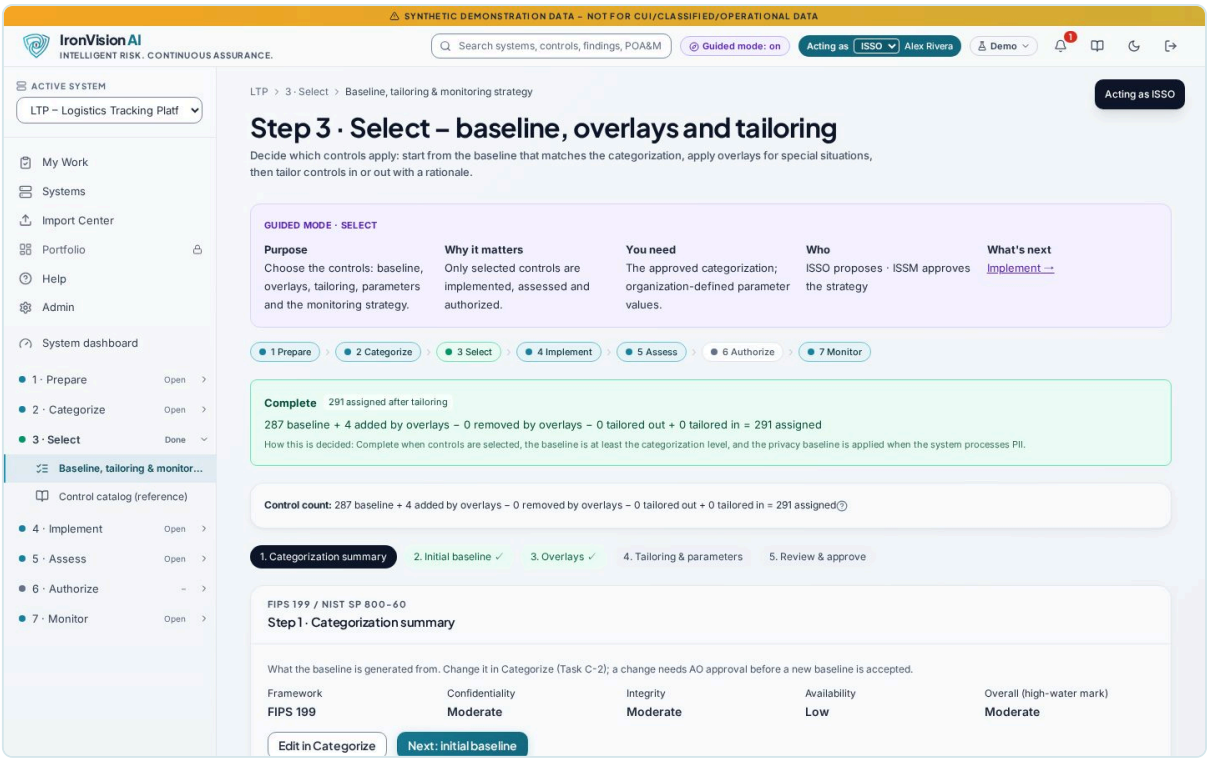


Figure: Select: baseline, overlays and tailoring

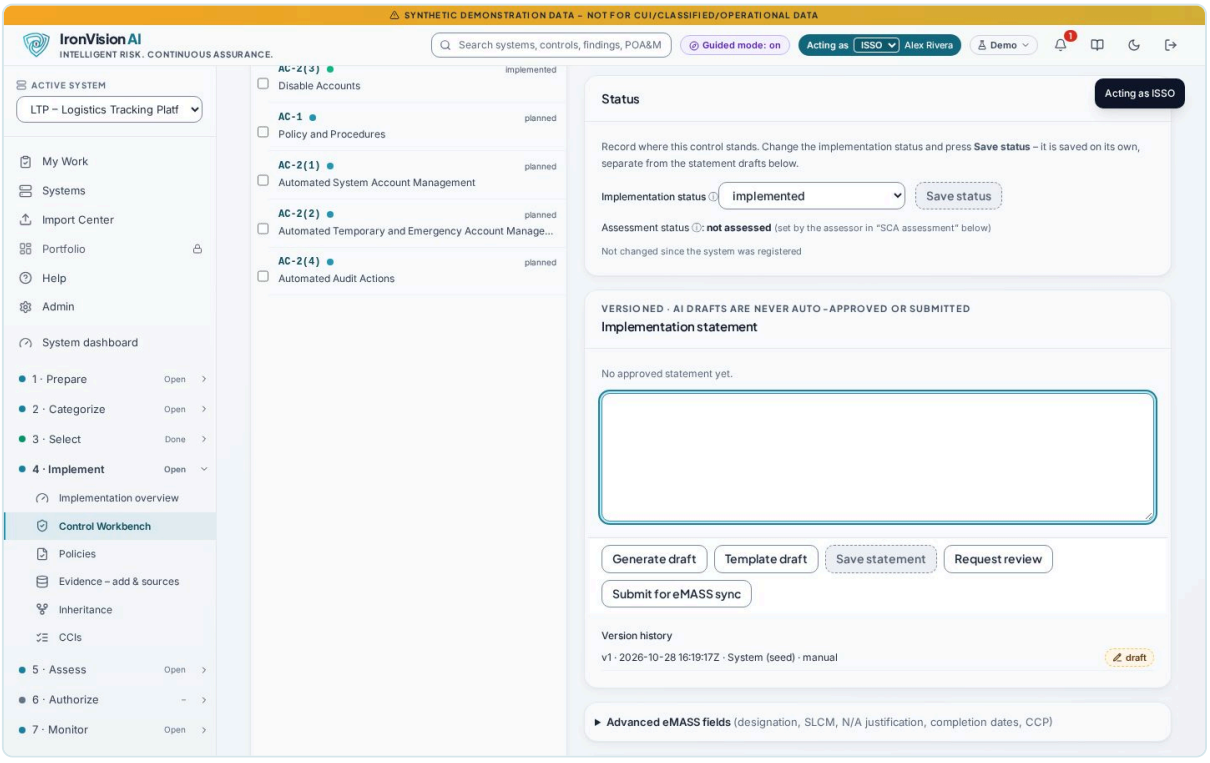


Figure: Control tab (AC-2): status, parameters and implementation statement

Control catalog (/catalog)

Purpose	Browse the pinned NIST SP 800-53 Rev. 5 catalog with assessment objectives, baselines and content versions.
Used by	All roles
Key actions	Search; filter by family or baseline; open control detail.
Outputs	None (read-only).
Guardrails	Content is SHA-256 verified at load.

5.6 Step 4 – Implement

Implementation progress (/rmf/implement)

Purpose	Progress of implementation statuses and statements across the system's controls.
Used by	ISSO, System Owner
Key actions	Filter by status or family; open the workbench.
Outputs	Counts consistent with the stepper.
Guardrails	Read-only summary.

Control Workbench (/controls, /systems/:id/controls/:controlId)

Purpose	The ISSO's main workspace: the control list (two primary filters, more filters collapsed, saved per system) beside one control in six tabs – Requirements, Implementation, Evidence & Policies, Assessment, Findings & POA&M, Monitoring. Status chips use one glossary (implementation, policy coverage, assessment determination, authorization, evidence freshness, POA&M) with tooltips; advanced eMASS fields are collapsed, not removed.
Used by	ISSO, System Owner, SCA (assessment tab)
Key actions	Save implementation status; write or AI-draft a statement (grounded in evidence, policies and POA&Ms); submit it for review; attach evidence; view policy mappings and coverage.
Outputs	Versioned implementation statements, review requests, eMASS Implementation Plan and Risk Assessment fields.
Guardrails	AI drafts are labelled, carry validated citations and need human approval. Only the SCA sets the assessment status.

eMASS Implementation Plan and Risk Assessment (Control Workbench panels)

Purpose	eMASS field names and values (Implementation Status, Security Control Designation, Estimated Completion Date, Responsible Entities, SLCM Criticality/Frequency/Method/Reporting/Tracking/Comments, N/A Justification, Common Control Provider; Severity, Relevance of Threat, Likelihood, Impact, Residual Risk Level and risk text). Required fields follow the eMASS API business rules for each status.
Used by	ISSO, System Owner (edit); other roles read-only
Key actions	Pick values from dropdowns (with Other… for free-text fields); Suggest values (AI or deterministic rules) and accept per field or all; bulk-set plan fields on selected controls; filter by eMASS status or missing required fields; Import from eMASS: upload an eMASS Control Information export (compatibility pending verification against a real eMASS export), review current vs imported values per field, accept or reject, then apply (audited with the file name and SHA-256). The same shared eMASS report import also recognises System Details, Test Results, POA&M and Hardware/Software List exports by their headers (each labelled compatibility pending verification against a real eMASS export), asks whether to update the current system, register a new one or pick an existing one, and shows one grouped review; Test Results stay proposals pending SCA approval and POA&Ms match by eMASS ID, then control + weakness.
Outputs	eMASS-formatted Implementation Plan xlsx (exported from the migration report and Authorize › Package & documents; the parameter comparison CSV is in Select › Tailoring & parameters; compatibility pending human verification), validation report, OSCAL SSP props/remarks, MOCKED eMASS sync payload with eMASS API field names.
Guardrails	One implementation status (eMASS status is derived from it). Inherited controls are read-only and their Risk Assessment cannot be edited. Suggestions are never saved automatically; accepted values are audited as AI- or rule-assisted. AI never sets compliance or test results.

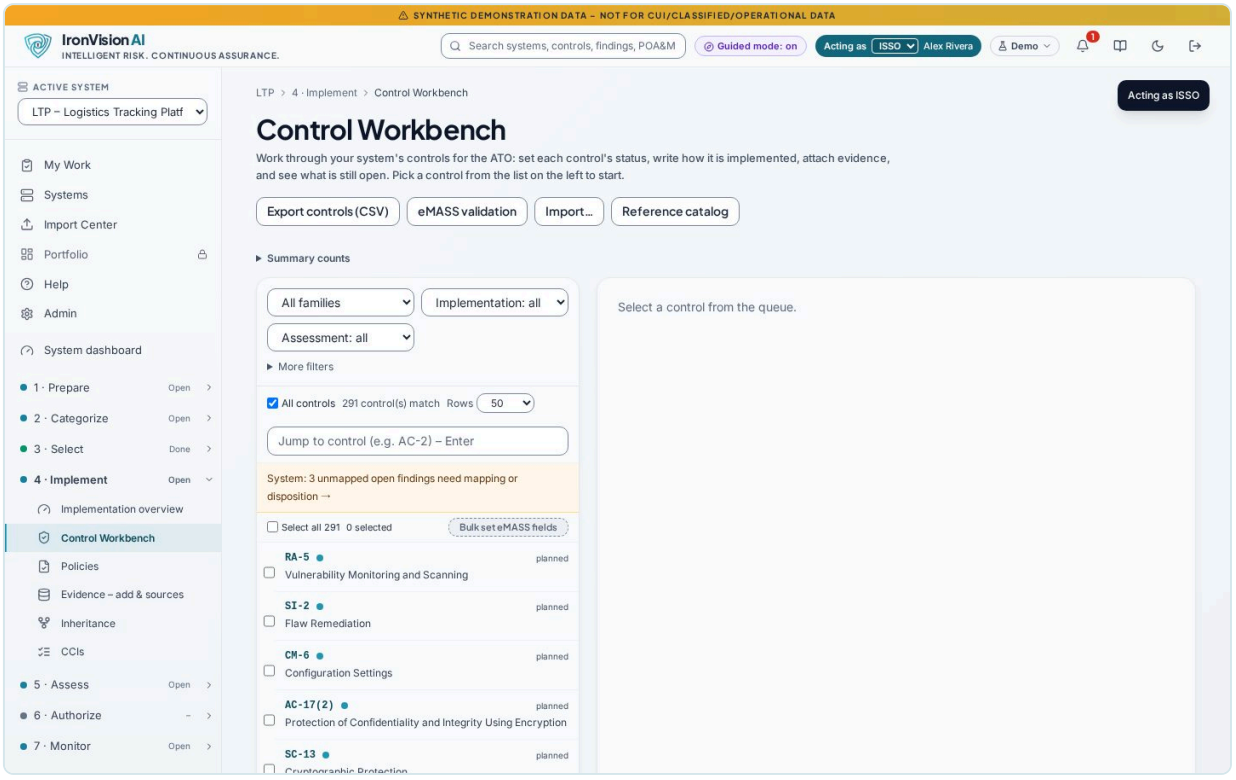


Figure: Control Workbench: list and control tabs

Inheritance (/inheritance)

Purpose	Common and hybrid control inheritance from providers (data centres, cloud platforms, enclaves).
Used by	ISSO, ISSM
Key actions	Add or edit providers with package, authorization type and expiry; import a customer responsibility matrix (CRM); bulk inheritance; owner attestations.
Outputs	Inherited, shared and system-owned responsibility per control.
Guardrails	Expired or expiring provider authorizations are flagged with the number of dependent controls.

HW/SW Inventory (/inventory)

Purpose	The eMASS hardware/software list together with scan-observed hosts.
Used by	ISSO, ISSM
Key actions	Import the HW/SW .xlsm; review correlations between scan hosts and assets; resolve consistency issues; export to the same template.
Outputs	Inventory records, discrepancy decisions, validated export.
Guardrails	See section 6 (AI) and section 9 (workbooks).

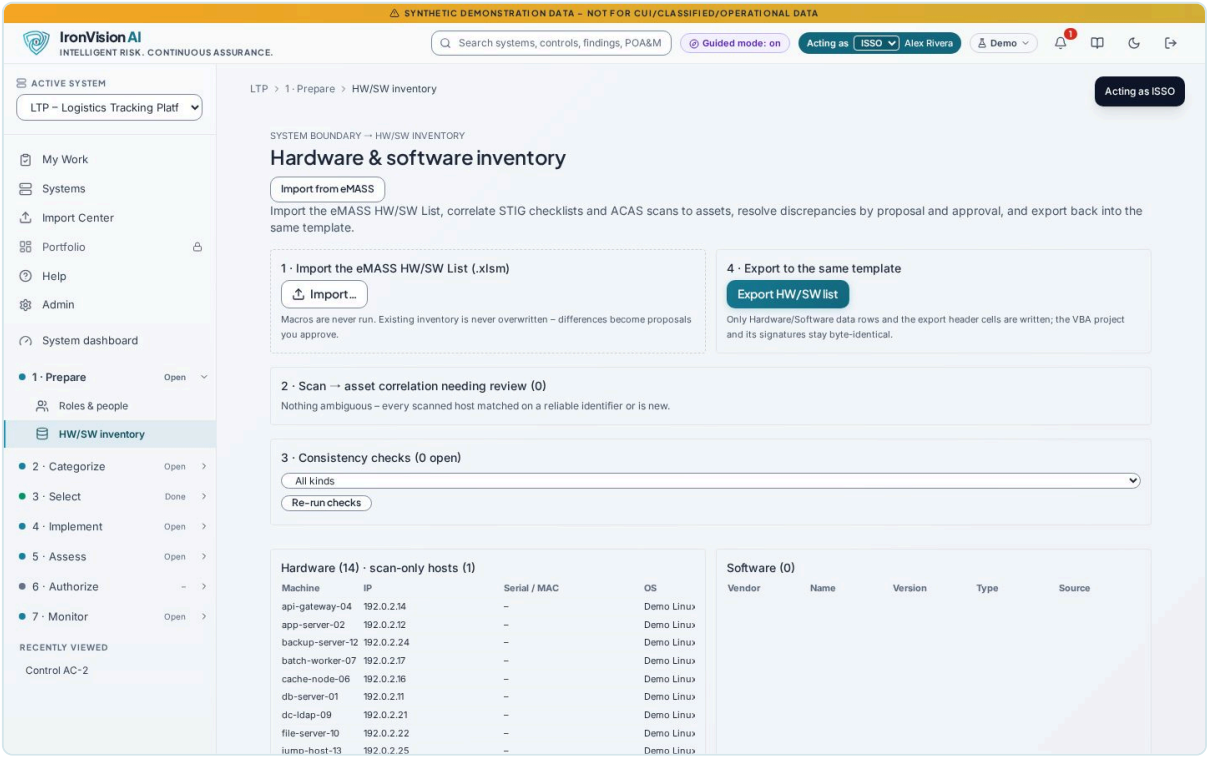


Figure: HW/SW Inventory overview

CCI view (/ccis)

Purpose	DISA CCIs of the system's controls with their policy coverage.
Used by	ISSO, SCA
Key actions	Filter by control, family or coverage status; open the source policy passage.
Outputs	Coverage per CCI.
Guardrails	Coverage comes from policy text only; 'covered elsewhere' links never turn MISSING into MET.

Policy Auditor (/policy-auditor, /policy-auditor/:id)

Purpose	Upload policies and procedures (PDF/DOCX/TXT). They are parsed into sections and pages, mapped to controls and evaluated against assessment objectives and CCIs.
Used by	ISSO, ISSM
Key actions	Upload; reanalyze; review proposed mappings; confirm, dismiss (with justification) or link findings; export CSV.
Outputs	Policy-to-control mappings with confidence and source (section/page), per-requirement coverage (met / partial / missing) with quotes.
Guardrails	Findings stay proposed until a human confirms them. AI may raise a requirement only with an exact quote. No silent misses: 'not present' is shown only after the whole document and a focused second look found nothing; otherwise the row is 'needs manual review' with candidate passages. Policy evidence supports at most Partially Implemented.

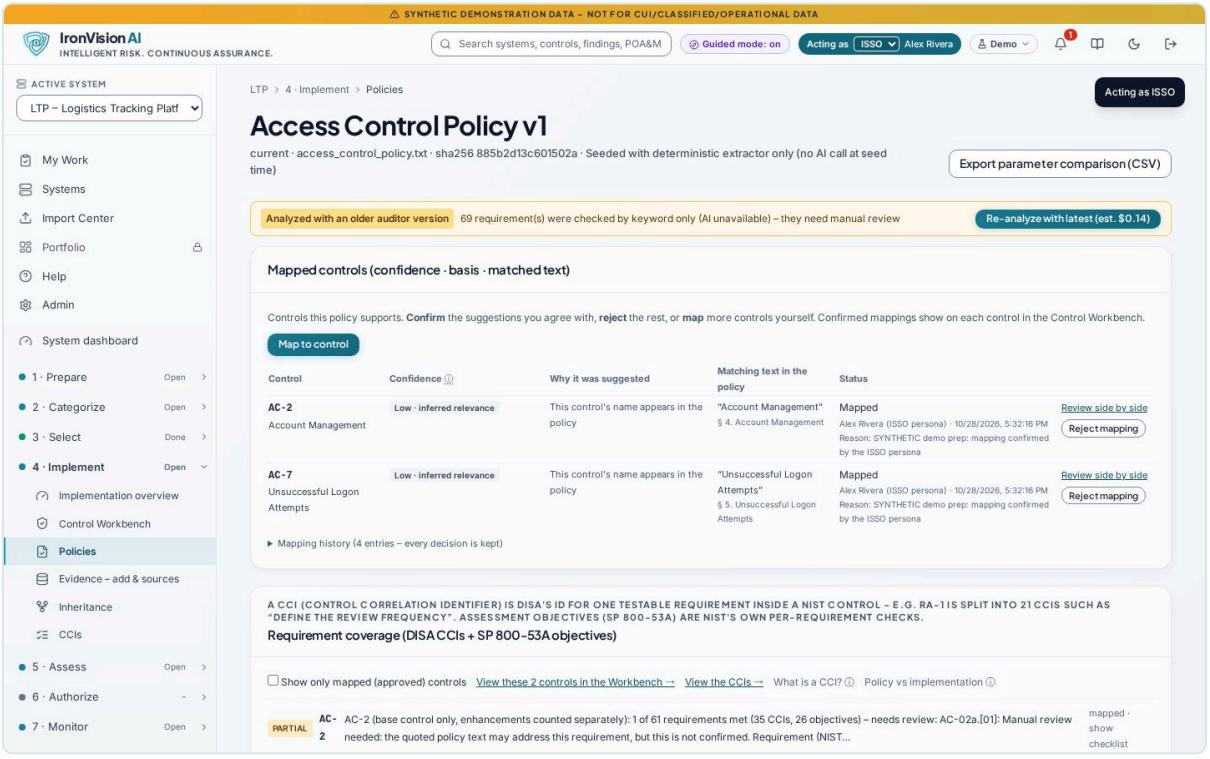


Figure: Policy mappings with confidence, matched text and decision history

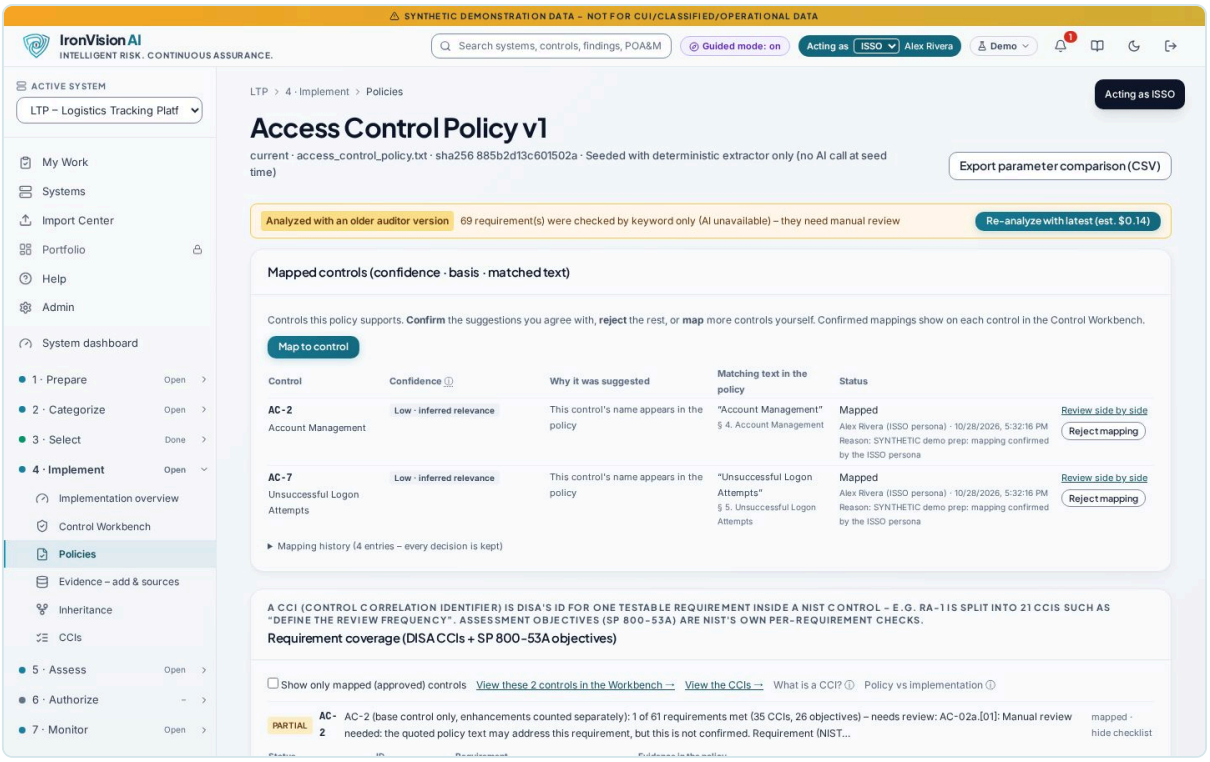


Figure: Requirement coverage: keyword-only rows flagged for manual review

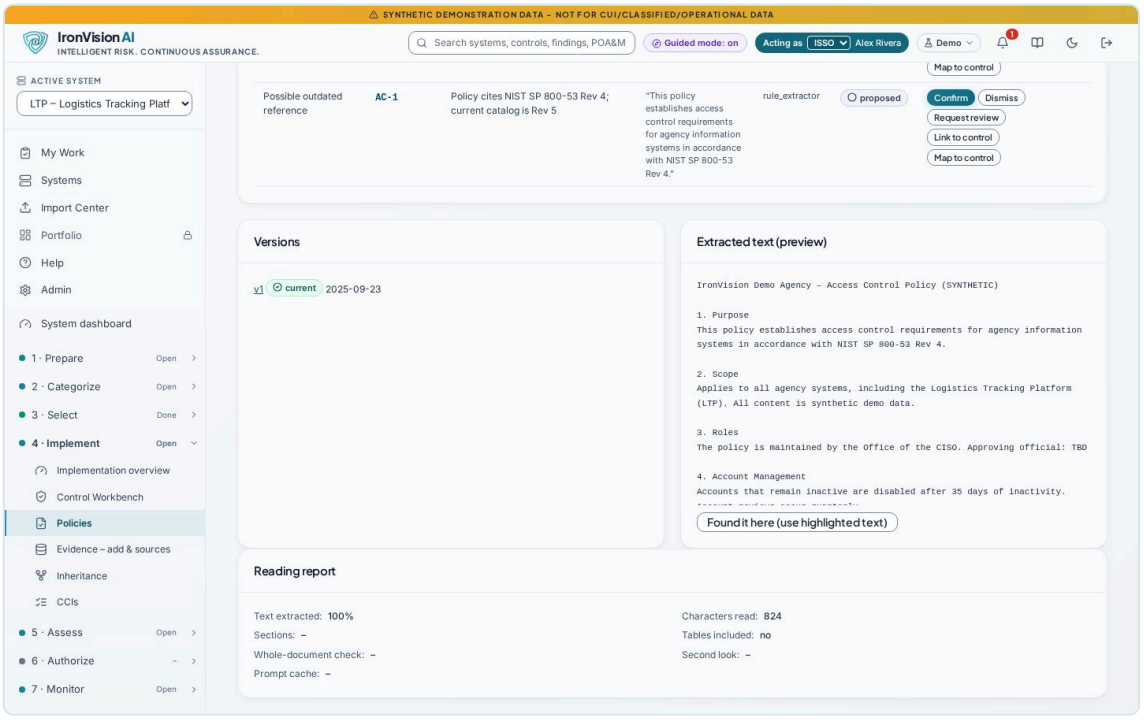


Figure: Reading report: what was read, whole-document check and second look

Evidence Sources (/evidence-sources, /ingest-runs/:id)

Purpose	Upload STIG checklists (.ckl/.cklb), ACAS/Nessus (.nessus/CSV), SCAP/XCCDF and other evidence, and manage connectors.
Used by	ISSO, DevSecOps
Key actions	Upload; follow an ingest run (processing → analysed / failed with reason); retry failed runs.
Outputs	Evidence records, canonical deduplicated findings, CCI→800-53 mappings, asset correlation.
Guardrails	Upload allowlists, magic-byte checks, size limits, safe XML parsing and archive checks.

MOCKED

Live connectors (scanner, cloud configuration and ticketing APIs) are **MOCKED** in this release. The MockAdapter contacts no external system, and its records are labelled 'MOCKED source · <collector>'. File import is the real ingestion path.

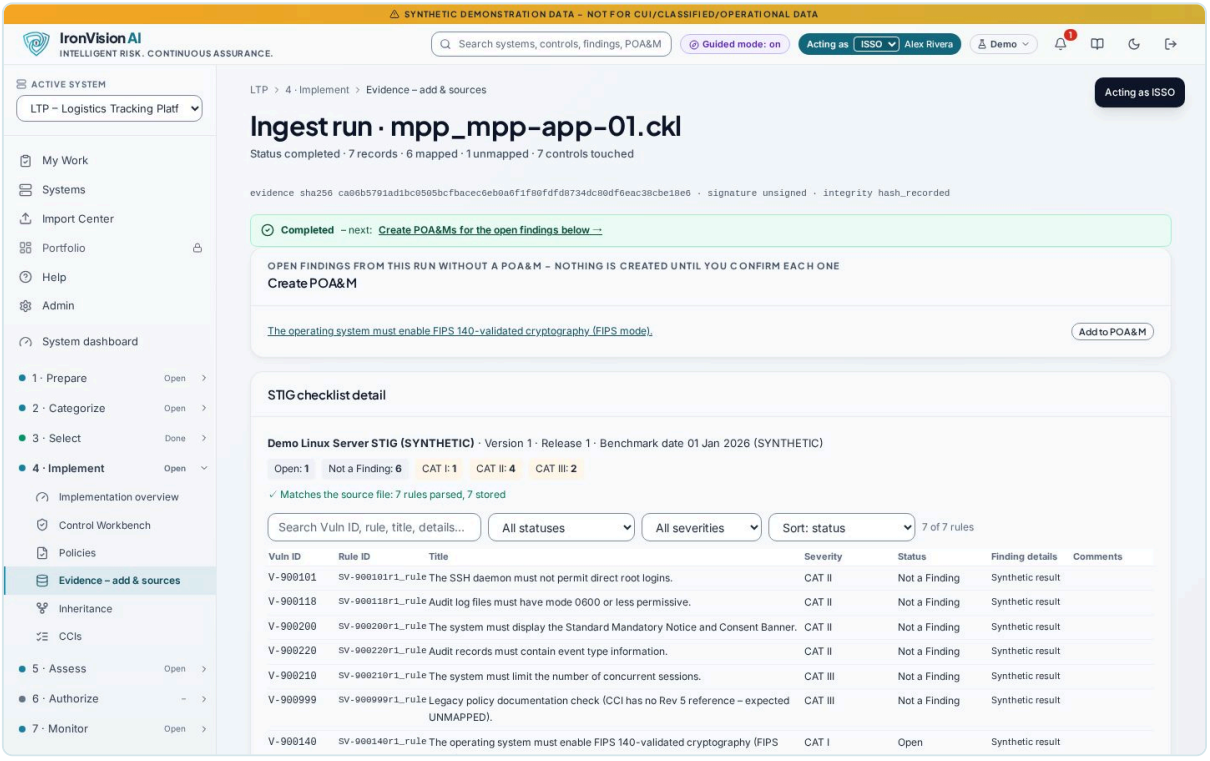


Figure: STIG ingest run detail

5.7 Step 5 – Assess

SCA assessment workspace (/assess/workspace)

Purpose	The SCA's single place to work: the assessment queue, imported Test Result workbooks waiting for review and the determination for the selected control with its implementation statement and evidence.
Used by	SCA
Key actions	Pick a control; review statement and evidence; record the determination; open the next one.
Outputs	Assessment determinations (existing assessment service).
Guardrails	Only the SCA records determinations; the workspace reuses the existing permissions and SCA independence rules.

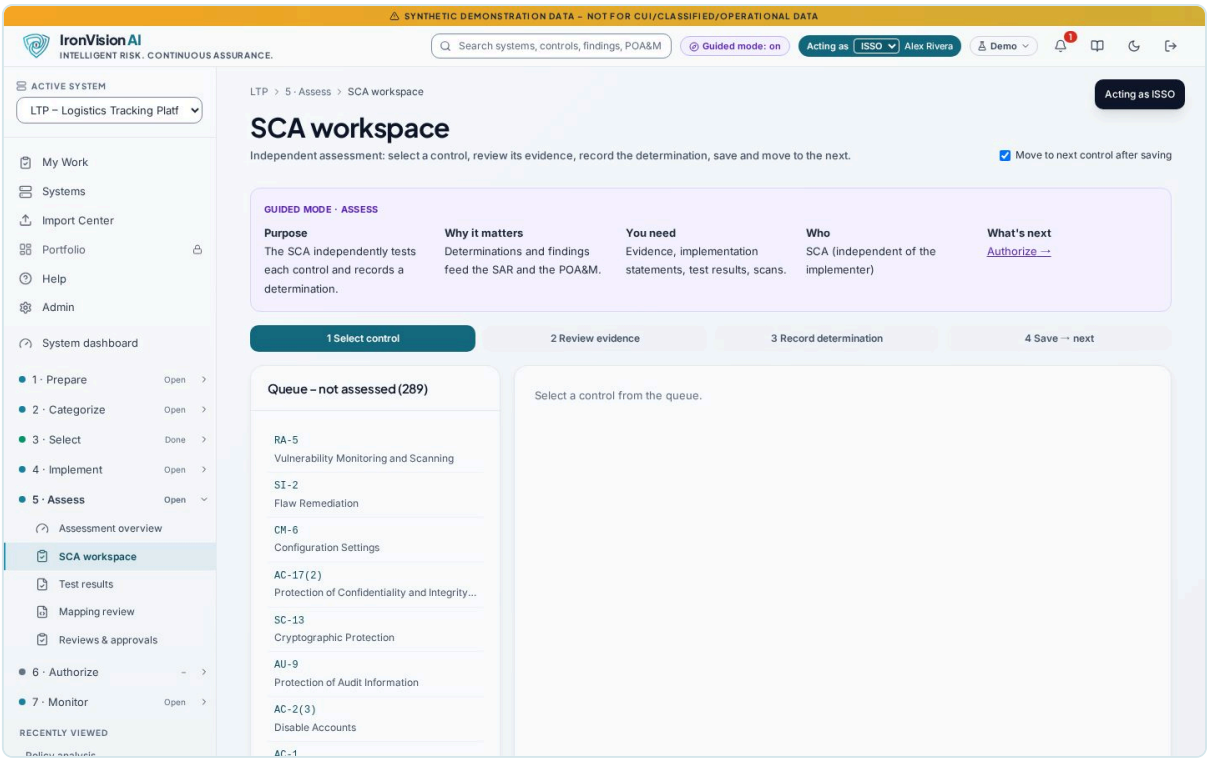


Figure: SCA assessment workspace

Assessment progress (/rmf/assess)

Purpose	Assessment coverage across the system's controls.
Used by	SCA, ISSM
Key actions	Filter; open controls to assess.
Outputs	Counts consistent with the stepper.
Guardrails	Read-only summary.

Reviews (/reviews, /reviews/:id)

Purpose	Every review request type (implementation statements, dispositions, closures, risk acceptances, extensions, categorization, authorization package) runs under versioned decision rules.
Used by	Requesters and the roles named in each decision rule
Key actions	Endorse, approve, return or deny, with comments.
Outputs	Decisions and their effects (applied only on approval).
Guardrails	Self-approval blocked; decision rules versioned and audited.

Templates → Test Results (/test-results)

Purpose	Import the eMASS Test Result template (blank or pre-populated), generate rows from assessments, scans, policy coverage and evidence, run AI evidence analysis, have the SCA approve rows, and export.
Used by	ISSO (prepares), SCA (approves)
Key actions	Import; resolve header and AP/CCI matching; review auto-suggested rows; run evidence analysis; 'Use this text'; SCA approval (single or bulk) with actual tester and test date; export with a validation report.
Outputs	Exported workbook, validation report, export history.
Guardrails	Only the SCA sets or approves Compliance Status. Approval requires 'Tested by' and a 'Date tested' not in the future. AI never sets Compliance Status, Tested By or Date Tested.

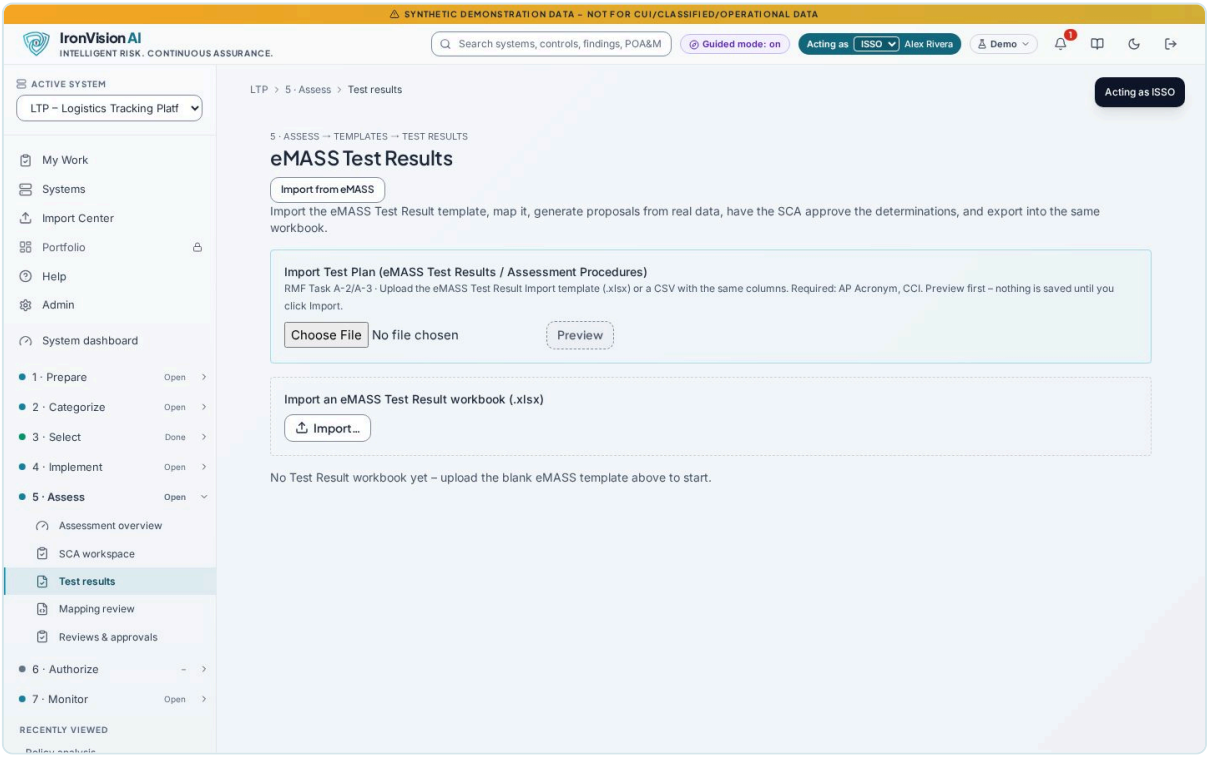


Figure: Test Results workbook (AI evidence analysis is suggestion-only)

Mapping Review (/mapping-review)

Purpose	One queue in three main tabs – policy coverage, STIG mappings, status suggestions (plus All, status-from-policy and awaiting SCA) – with a side-by-side view of the source passage and the control requirement. Pending suggestions are also shown on the control.
Used by	ISSO, ISSM
Key actions	Accept or reject proposals; map unmapped rules (with optional AI suggestion); disposition with justification.
Outputs	Human-approved mappings.
Guardrails	AI suggestions are proposals; dispositions create reviews.

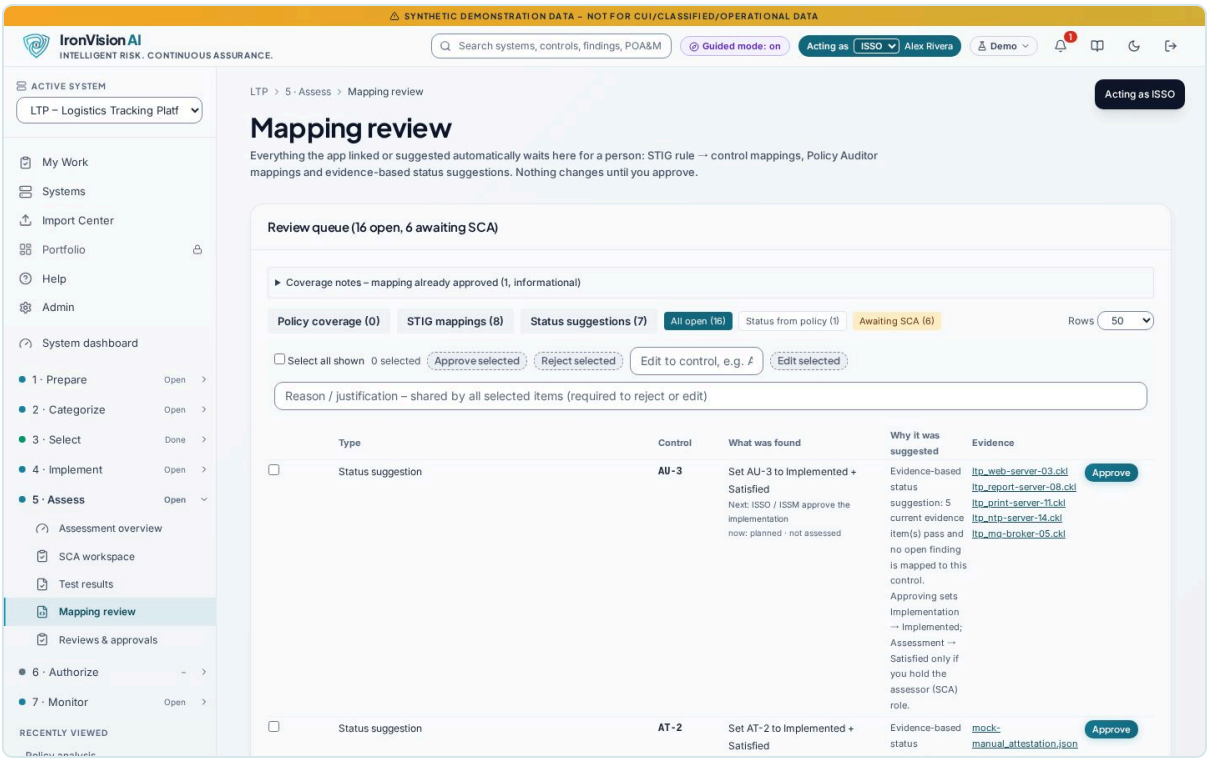


Figure: Mapping Review queue with confidence filters

5.8 Step 6 – Authorize

Authorization package (/rmf/authorize, /systems/:id/authorization)

Purpose	Assemble the package, request ISSM endorsement and AO decision.
Used by	ISSO, ISSM, AO
Key actions	Submit; endorse; decide ATO / ATO with conditions / IATT / DATO with expiry and conditions.
Outputs	Authorization decision record; authorization type and expiry drive the Portfolio view.
Guardrails	Only the AO decides; denials are audited.

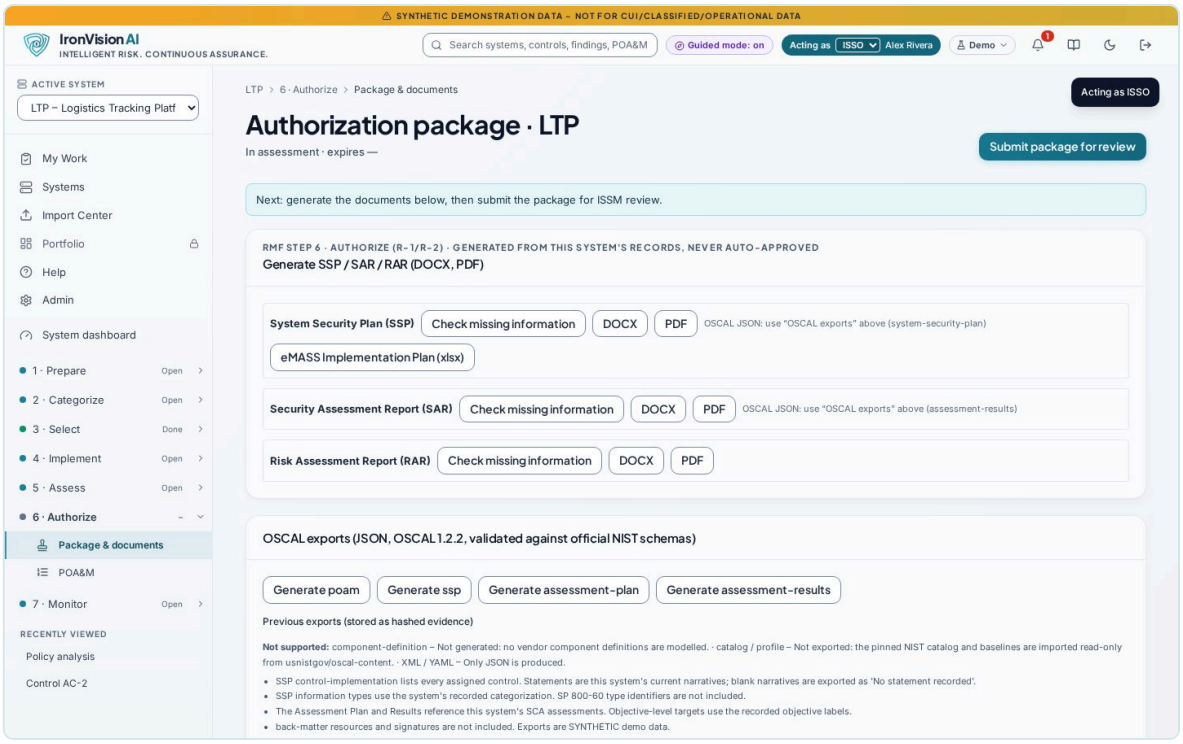


Figure: Authorize: package, OSCAL exports and decision

POA&M (/poams, /poams/:id)

Purpose	Plan of Action and Milestones with weaknesses, milestones, risk, linked findings and history.
Used by	ISSO, ISSM, AO (risk acceptance)
Key actions	Create from findings (match/link rules); add milestones; request closure, risk acceptance or extension.
Outputs	POA&M records; OSCAL POA&M export.
Guardrails	Remediation detection marks items closure-eligible but never closes them automatically. Status cannot change while a closure or risk review is pending. Later due dates need an extension request.

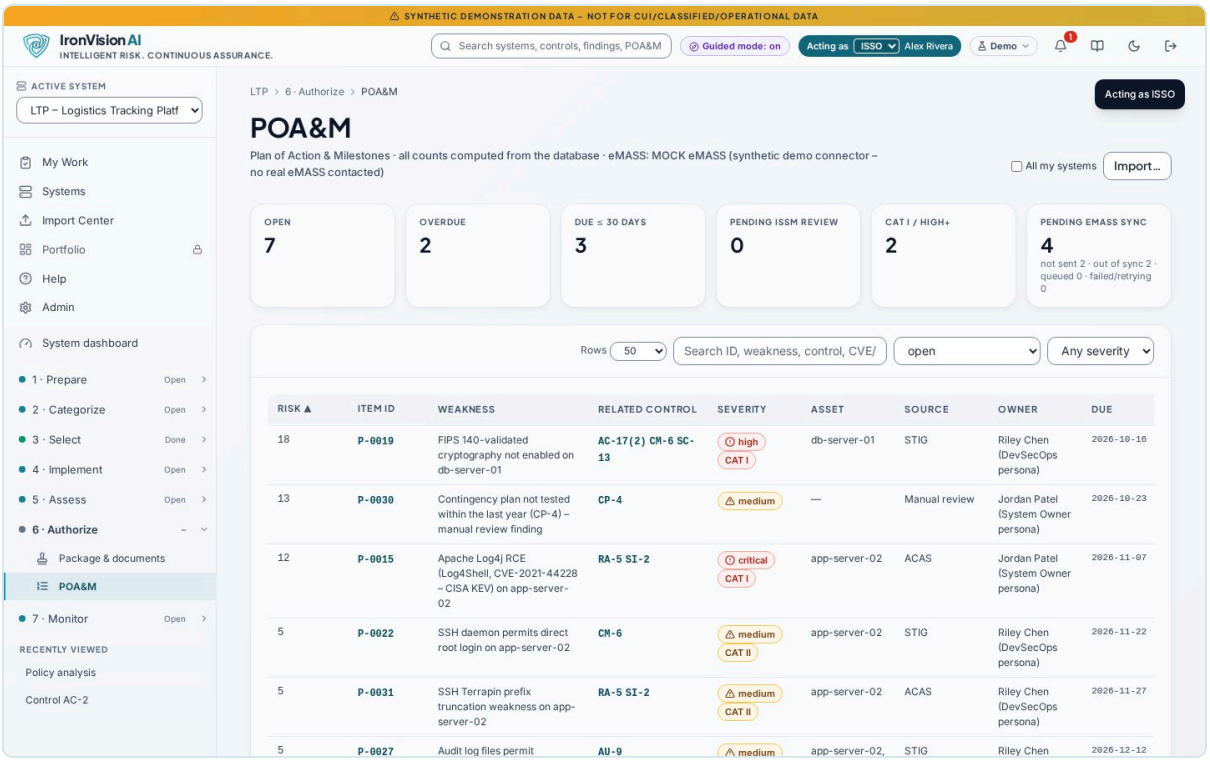


Figure: POA&M list

eMASS Sync (/emass)

Purpose	Connector setup, approval-gated outbound queue, compare/import, retry with back-off, conflict resolution and failure simulation.
Used by	ISSO, ISSM (queue), Platform Admin (connector)
Key actions	Queue changes; approve; resolve conflicts ('keep local' needs a fresh ISSM approval).
Outputs	Sync history.
Guardrails	Truthful setup panel showing which capabilities are real.

MOCKED

The default eMASS adapter is **MOCKED** ('MOCK eMASS – synthetic demo connector, no real eMASS contacted'). The authorized read/write REST adapters are stubs that require credentials and have **not** been run against eMASS.

5.9 Step 7 – Monitor

Continuous monitoring (/rmf/monitor)

Purpose	Rule-based monitoring status: CISA KEV matches, CAT I findings, overdue POA&Ms, stale evidence, scheduled job health.
Used by	ISSO, ISSM
Key actions	Open the items that need attention.
Outputs	Monitoring status feeding step 7.
Guardrails	KEV is versioned content (pinned CISA snapshot) re-evaluated daily; EPSS is not loaded (labelled).

Evidence Ledger (/evidence-ledger)

Purpose	Tamper-evident list of all evidence with SHA-256, provenance, freshness, integrity status and versions.
Used by	ISSO, SCA, ISSM
Key actions	Verify integrity; view, replace (new version) or remove (with reason) evidence; see dependents flagged for re-review.
Outputs	Integrity checks, version history.
Guardrails	Removal and replacement keep history and flag dependent controls.

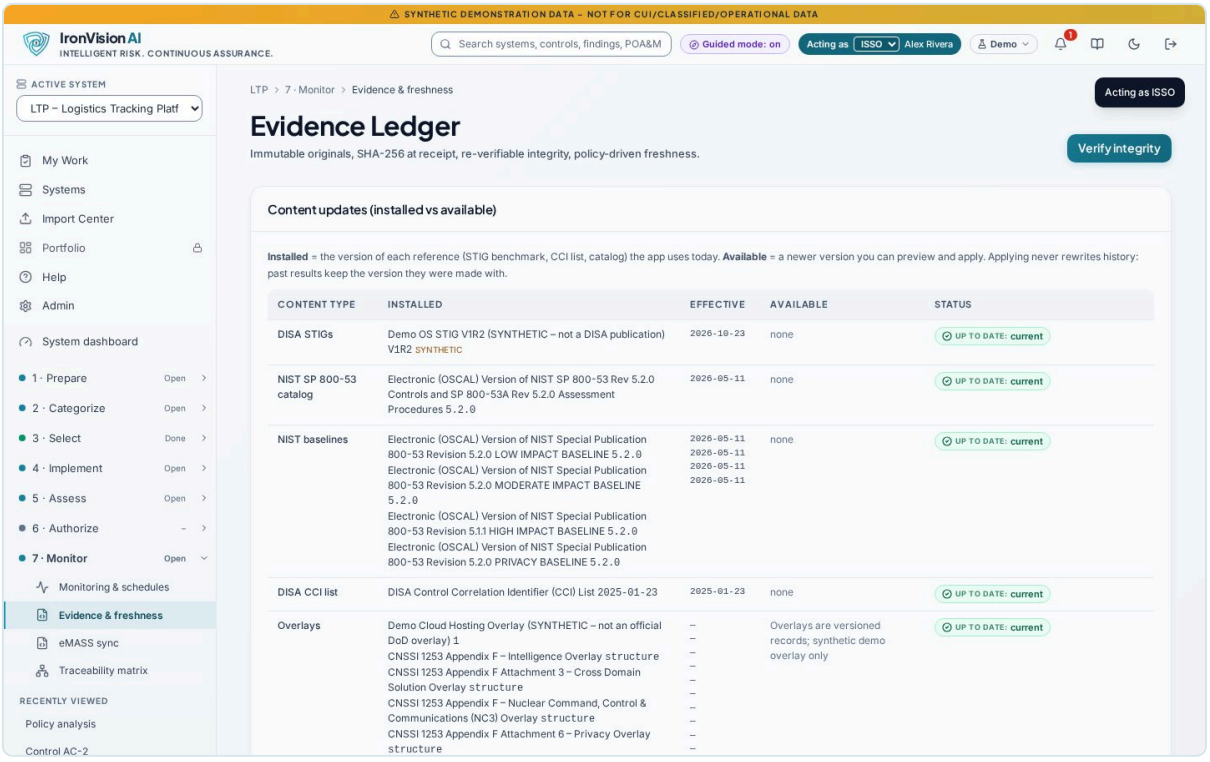


Figure: Evidence Ledger

5.10 Tools and administration

Traceability matrix (/traceability)

Purpose	Control → implementation → evidence → finding → POA&M → assessment chain.
Used by	SCA, ISSM, AO
Key actions	Filter; follow links.
Outputs	Traceability view.
Guardrails	Read-only.

Help: who can do what (/help)

Purpose	Plain-language permission matrix and role descriptions.
Used by	All
Key actions	Read.
Outputs	—
Guardrails	—

Audit Log (/audit-log)

Purpose	The hash-chained audit trail with filters, pagination, chain verification and CSV/JSON export.
Used by	ISSO, ISSM, SCA, AO, Privacy Official, Platform Admin (audit.read)
Key actions	Filter by action, outcome, actor; verify chain; export.
Outputs	Exports.
Guardrails	Append-only; the retention job refuses to purge audit events.

Admin (/admin)

Purpose	Platform health (database, storage, worker heartbeat, AI), AI status and 'Test AI connection', RBAC enforcement demo, worker jobs and schedules, users and roles, security status, AI administration (model override, use cases), decision rules, content updates, demo tools.
Used by	Platform Admin (most panels), all roles (health and AI status)
Key actions	Run health checks; test the AI connection; enqueue content loads; invite users (dev); edit decision rules; edit the banner.
Outputs	Health, audit entries.
Guardrails	Panels are permission-gated with an explicit 'Your roles do not grant ...' message. No secrets are shown.

Docs Center (/docs-center)

Purpose	In-app handover documentation (deployment, security, operations).
Used by	Admins, operators
Key actions	Read.
Outputs	—
Guardrails	—

Notifications (/settings/notifications) and global search

Purpose	Per-user notification preferences; RBAC-filtered search across systems, controls, findings and POA&Ms.
Used by	All
Key actions	Set preferences; search.
Outputs	—
Guardrails	The email adapter is disabled by default.

Sandbox controls (header)

Purpose	Sandbox badge, 'Acting as' persona switcher, demo reset (demo tools).
Used by	Sandbox users
Key actions	Switch persona; reset the demo workspace.
Outputs	—
Guardrails	Only on sandbox tenants; persona actions are labelled.

6 AI components

All AI calls go through one service (backend/app/services/ai/service.py). Every prompt is versioned (id@version) and declares a strict output schema (Pydantic). Each call is logged to the ai_interactions table: provider, model, prompt id and version, input SHA-256, token usage, latency, validation status and correlation id. Output that fails schema validation gets exactly one repair retry. A reply cut off at the output-token limit (finish_reason 'length') is detected and retried as a smaller batch. If it still fails, the deterministic result stands.

6.1 Inventory of AI features

Feature (prompt)	Inputs	Output	Grounding / validation	Fallback
Policy audit (policy.audit@1.0.0)	Policy text, mapped control, ODP / observed values	Proposed findings (gaps, value mismatches)	Schema; findings stay proposed until a human confirms	Deterministic parser findings
Policy coverage refine (policy.coverage_refine@2.x)	Assessment objectives / CCIs of one control (batches of 8), deterministic result, policy text	met / partial / missing + exact quote + rationale per requirement	Quote must be an exact contiguous substring of the policy; otherwise the AI result is discarded and noted; disagreement lowers confidence and needs review	Per-batch deterministic coverage
Mapping suggestion (mapping.suggest@1.0.0)	Finding title, source, rule/plugin, CVEs, CCIs	Up to 3 controls with rationale and confidence	Control IDs validated against the catalog; proposal only	Manual mapping
Implementation statement draft (control.implementation_statement@1.0.0)	Control, system context, evidence, policies, open POA&Ms	Sectioned draft with citations	Citations validated against real records; draft versioning; review request required	Manual writing
TR evidence analysis (tr.evidence_analysis@1.1.0)	TR row (CCI / AP), linked evidence, STIG/ACAS results, policy coverage, POA&Ms	Per-source verdict, reason, quote and suggested Test Results text	References must exist; quotes verified; fields compliance_status / tested_by / date_tested are rejected by the schema	Deterministic analysis label
Inventory correlation ranking (inventory.correlation_rank@1.0.0)	Scan host facts and candidate assets	Ranked candidates with confidence and identifiers	Fabricated candidates and unsupported identifiers dropped; creates no asset or finding	Deterministic correlation engine

Feature (prompt)	Inputs	Output	Grounding / validation	Fallback
Discrepancy explanation (inventory.discrepancy_explain@1.0.0)	An inventory discrepancy and its records	Plain-language explanation and ranking	References validated; suggestion only	Rule text
Connection test (ai.health_check@1.0.0)	A random nonce	Status, echoed nonce, one-sentence summary	Nonce must match	—

AI IS NEVER ALLOWED TO

Set or approve a Compliance Status, assessment result, authorization decision or risk acceptance; fill in 'Tested by' or 'Date tested'; close a POA&M; approve its own suggestion; make a privacy determination; create assets or findings; change inventory records; or bypass the human approval gate, which is locked on.

6.2 Provider architecture

The provider is chosen with environment values only: AI_PROVIDER, AI_MODEL, an optional per-use-case AI_MODEL_DRAFTING / _POLICY / _MAPPING / _SUMMARY, AI_TIMEOUT_SECONDS and AI_MAX_OUTPUT_TOKENS (default 8000). Switching providers takes an env change and a restart of the backend and worker. A platform admin can override the model in the Admin page; this is audited.

AI_PROVIDER	Transport	Notes
openrouter (recommended)	OpenAI Chat Completions over HTTPS, base https://openrouter.ai/api/v1	One key (OPENAI_COMPAT_API_KEY); any model slug passed verbatim; structured output negotiated json_schema → json_object → prompt; 429/502/503 retried honouring Retry-After; clear 401/402/404 messages
anthropic	Anthropic Messages API	ANTHROPIC_API_KEY; direct adapter (not exercised against the live API in development)
openai_compatible	Any OpenAI-compatible endpoint (vLLM, Ollama, LM Studio, gateways)	Keeps data inside your boundary when self-hosted
emergent	Emergent universal key	Development preview only; refused in staging and production
none / empty	—	All features run in deterministic mode

6.3 Status, health and usage

- **GET /api/v1/ai/status** (every signed-in role): provider / model, configured yes/no, analysis mode ('AI-assisted (provider / model)' or 'Deterministic analysis (no AI)'), endpoint, whether a key is configured (never the key), last successful call, 24-hour call and token usage. Only admins see the last error.
- **POST /api/v1/ai/health** (platform admin, 'Test AI connection'): one tiny call returning provider, model and latency. Success and failure are both audited.
- **GET /api/v1/health**: platform health including the AI component.

- The API key is sent only as a bearer header. It is never logged, returned or shown.

> **NOTE**
> With OpenRouter, prompts go to OpenRouter and on to the provider of the selected model. Choose models and routing settings (data retention, no training) that fit your data policy, or use a self-hosted openai_compatible endpoint for data that must stay inside your boundary. Development and staging use synthetic data only.

7 Reference content

Reference content is pinned, versioned and SHA-256-verified at load. Updates are previewed (diff and impact) and applied only by a role with content.apply. History is never rewritten: observations and assessments keep the content version they were made against.

Content	Version / source	Loaded
NIST SP 800-53 Rev. 5 controls	OSCAL catalog (5.1.x)	1,196 controls: 324 base, 872 enhancements, 182 withdrawn
NIST SP 800-53A assessment objectives	OSCAL	3,715 objectives
NIST SP 800-53B baselines	OSCAL profiles	Low 149 · Moderate 287 · High 370 · Privacy 96
DISA CCI list	Pinned DISA CCI XML	5,137 CCIs; 3,838 CCI → Rev. 5 mappings, all resolved
NIST SP 800-60 Vol. 2 Rev. 1	Appendices C and D	168 information types (C: 76, D: 92) with provisional C/I/A
CNSSI 1253 Appendix D	29 July 2022, corrected copy 6 Oct 2022 (161 pp.)	1,189 rows (Tables D-1 … D-20), 182 withdrawn, page-cited
CNSSI 1253 parameter values	Appendix D 'Parameter Value' column	162 controls with values; 204 mapped to single ODPs; 27 kept at control level
CNSSI 1253 overlays	Official attachments (e.g. Classified, Privacy, Space)	13 overlay records; restricted overlays shown as unavailable
CISA KEV	Pinned snapshot	Re-evaluated daily against findings
STIG content	Versioned releases (demo data synthetic)	Diff and impact preview before apply
OSCAL schemas	OSCAL 1.2.2	SSP, POA&M, Assessment Plan, Assessment Results

7.1 CNSSI 1253 baseline numbers (selected = 'X' or '+')

Impact level	Confidentiality	Integrity	Availability
Low	273	310	147
Moderate	319	380	202
High	397	474	283

The privacy control baseline has 93 rows. Example unions: L-L-L = 394 (357 security plus privacy), M-M-M = 492, M-H-L = 559, H-H-H = 607. Thirty rows were checked by hand against rendered PDF pages and are pinned in the test suite. Compared with SP 800-53B: all 149 Low controls are selected at L-L-L; 286 of 287 Moderate at M-M-M (IA-12(5) is '--'); 369 of 370 High at H-H-H.

SME REVIEW REQUIRED

Union interpretation: the NSS baseline is computed as (C column at the C level) ∪ (I at the I level) ∪ (A at the A level) ∪ the privacy control baseline, with no high-water mark. CNSSI 1253 §3.2.1 does not use the word 'union'. Seven Rev. 5 controls that are not in the 2022 tables (IA-13 and its enhancements, SA-15(13), SA-24, SI-2(7)) are not selected and are listed for SME review.

SME REVIEW REQUIRED

Privacy Overlay / ACCT layering: whether ACCT layers under Low/Moderate/High exactly as the variant switcher assumes (CNSSI 1253F Att. 6 Table 2). ACCT covers 23 of the 27 privacy controls left to the overlay; SA-4, SC-7(24), SI-12(2) and SI-19 are shown as 'not covered – SME review'.

SME REVIEW REQUIRED

Privacy Threshold Analysis defaults: the shipped questionnaire is a generic example and must be validated by the agency's privacy office.

8 Evidence and data integrity

- **Content addressing.** Every uploaded file is stored under its SHA-256. File names are never used as storage paths. Duplicate uploads are detected by hash.
- **Provenance.** Each evidence item records its source (upload, connector, generated export), uploader, ingest run, linked controls and scan status ('not_scanned' when no ClamAV scanner is configured).
- **Integrity verification.** A worker job re-reads each object, recomputes SHA-256 and records an integrity check. The Evidence Ledger shows the current integrity status and the last verification time.
- **Freshness.** Freshness policies define a window per evidence type. Controls are rolled up as current, partially stale or expired per asset ('N of M assets'). Stale evidence feeds Continuous Monitoring.
- **Versioning.** Replacing evidence creates a new version with a reason. The previous version is kept, and dependent controls and TR rows are flagged for re-review. Removal requires a reason and is audited.
- **Retention and legal hold.** Retention rules per resource type purge only after their window; items under legal hold are never purged. Every purge supports a dry run and is audited. The audit log itself is never purged.
- **Generated artifacts.** OSCAL exports and workbook exports are stored as hashed evidence with their validation reports.

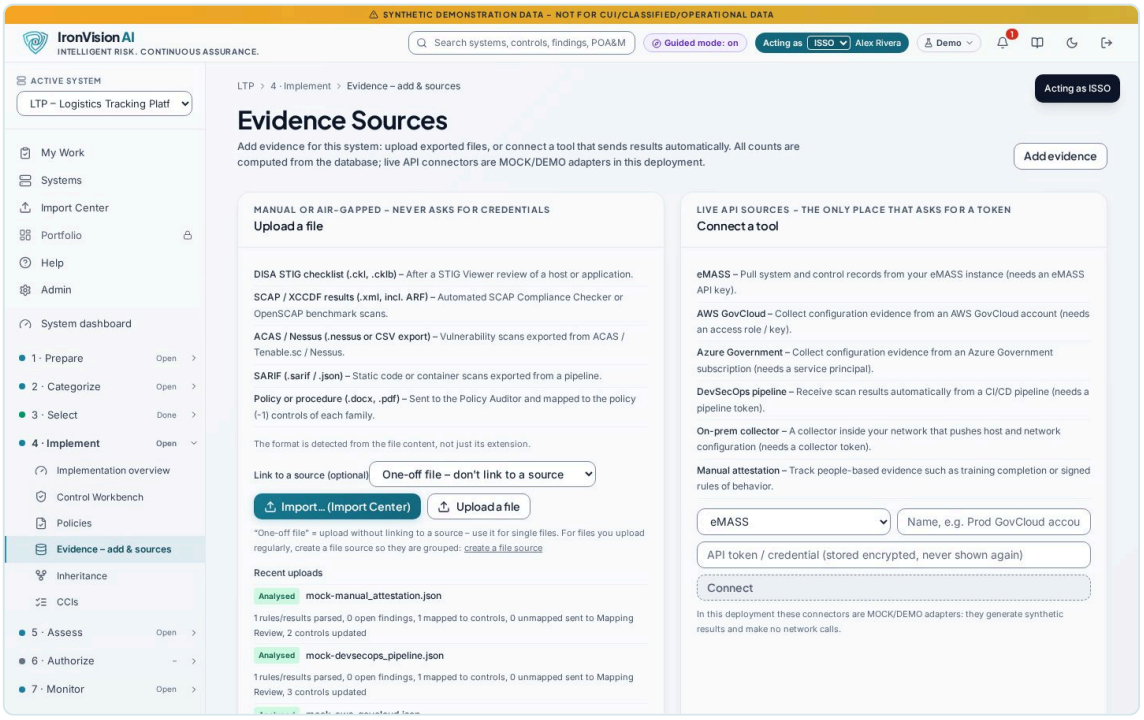


Figure: Evidence sources and connectors

9 eMASS workbooks

9.1 Test Result (TR) workbook

- **Import:** the real eMASS Test Result template. Header roles are detected (control acronym, AP acronym, CCI, CCI definition, implementation guidance, assessment procedures, Compliance Status, Date Tested, Tested By, Test Results). AP/CCI rows are matched to the system's controls, with manual resolution, and the mapping is saved as a reusable template definition.
- **Generation:** rows are proposed from SCA assessments, STIG/ACAS results, policy coverage, evidence freshness and POA&Ms, with missing, conflict and stale flags.
- **Approval:** only the SCA approves. Each approval records the actual tester and test date (not the approver or today's date). Rows approved under an older rule were marked 'needs confirmation'.
- **Two export modes, detected automatically.** Pre-populated mode (rows came from eMASS) writes only columns M–P (Compliance Status, Date Tested, Tested By, Test Results) of SCA-approved rows. Blank-template mode also writes the identifiers A/F/G/H, but only on rows added from the system, because eMASS needs them to identify each added row.
- **Validation report:** every cell outside the permitted ranges is compared (value, formula, style) and every other package part byte-for-byte. The report lists the mode, the permitted ranges with a reason for each, and the changed cells.

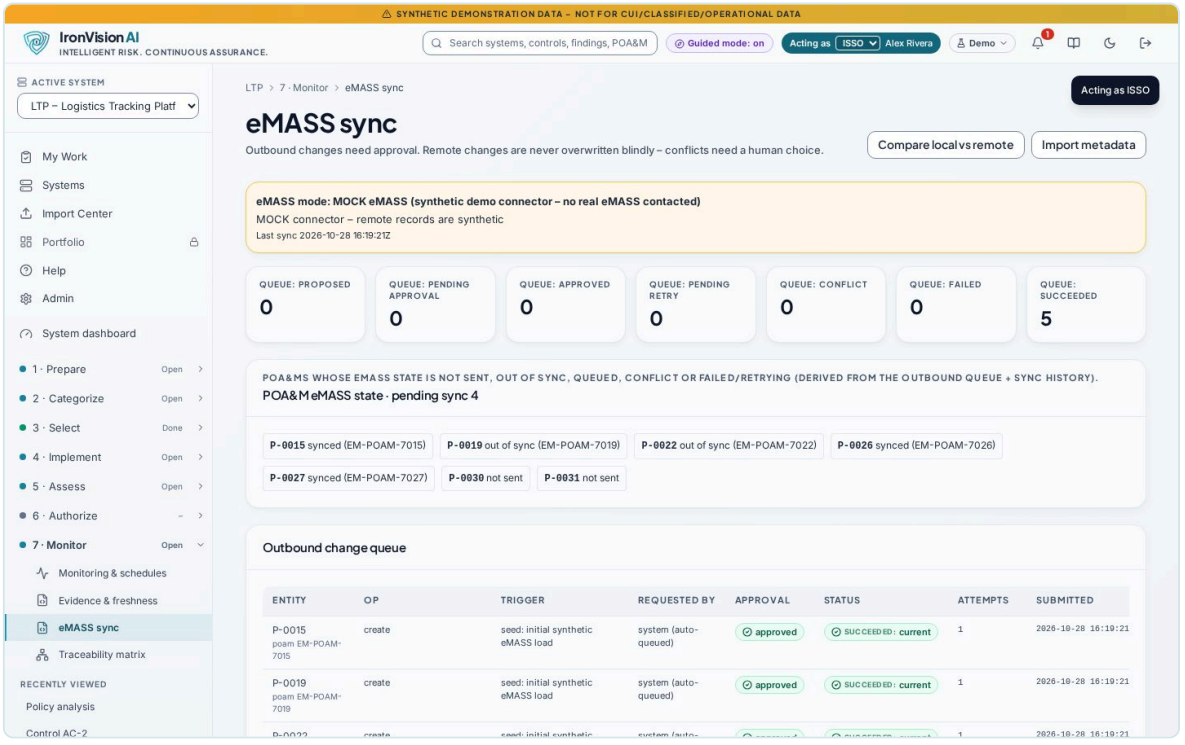


Figure: eMASS sync hub and outbound change queue

9.2 Hardware/Software (HW/SW) list

- Import of the eMASS HW/SW .xlsm. Headers are detected and vocabularies come from the template's '(U) Lists' tables. Existing records are never overwritten without proposal → accept → approve.

- **Macros are never executed.** The workbook is processed as an OOXML package. On export, vbaProject.bin and the three signature parts stay byte-identical to the template, and only permitted cells are written.
- Every export comes with a validation report.

> **REQUIRES HUMAN VERIFICATION**
> Open both exported workbooks in Microsoft Excel (macros disabled) and confirm there is no repair prompt and that the dropdowns still work. Import the TR export (Assessment → Test Result Import) and the HW/SW export into eMASS, and spot-check rows. eMASS import compatibility has not been verified in the development environment.

9.3 Import Center and Manage imported data

- **One drop zone for every import.** eMASS Control Information, Implementation Plan, Test Results / Test Plan, HW/SW, PPSM, STIG .ckl/.cklb, ACAS/Nessus and policies. Each file is detected and routed; the user chooses 'Register a new system' or 'Add to the current system', and several files can be imported at once.
- **Review before apply.** Changes are grouped by section with safe / conflict / invalid states; nothing is written until a human applies.
- **Manage imported data.** Every applied import has a Manage view grouped by section. Users restore, clear or delete one value, a row, a section or everything the import created (the system shell stays; system deletion is unchanged). Deletions can be undone for 30 days and every action is audited.
- **Decisions are never deleted.** If removed data underpinned an SCA determination, approved inventory, the AO's categorization or the ISSM's strategy, that decision is flagged for re-review. Removing imported evidence removes the link only; deleting the stored file needs a separate confirmation. Deleted Test Result rows and inventory items are excluded from both TR export modes.

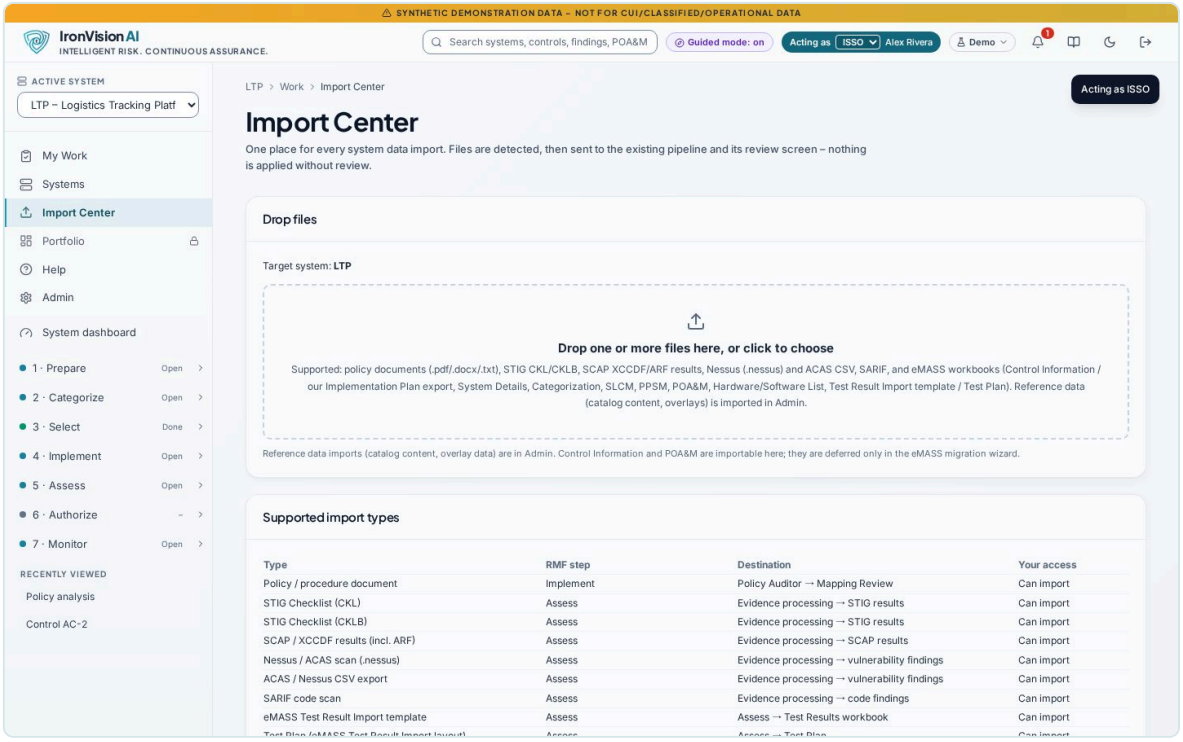


Figure: Import Center: drop zone and supported import types

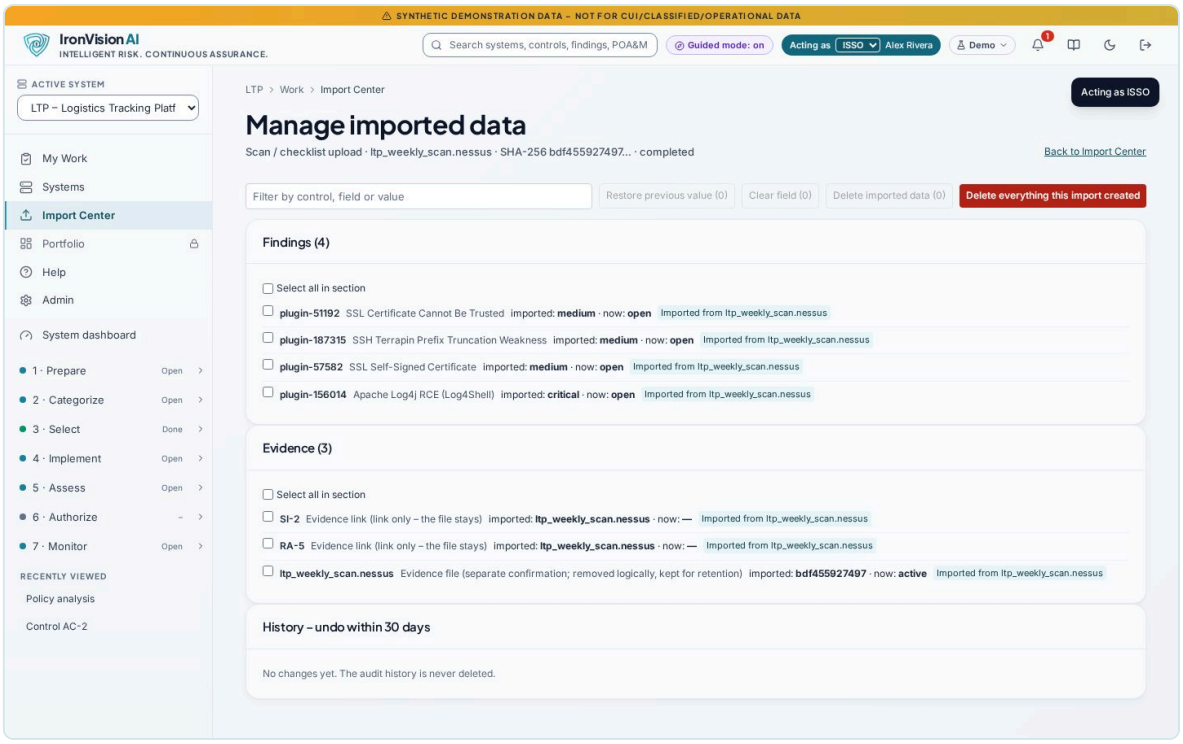


Figure: Manage imported data: sections, per-item delete, 30-day undo

10 Technical architecture

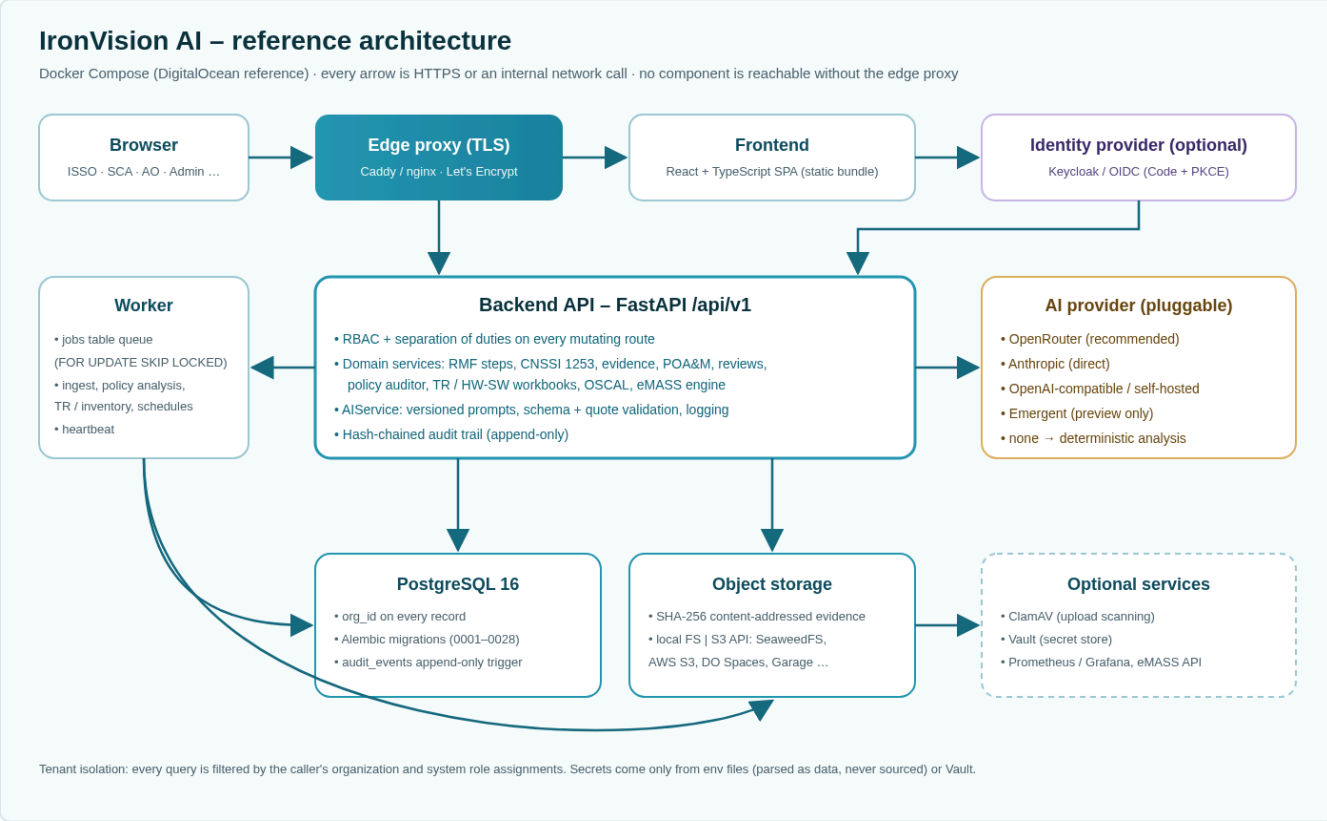


Figure: Reference architecture

Layer	Technology	Responsibility
Frontend	React + TypeScript, Tailwind design tokens, shadcn/ui	Page per RMF module; permission-aware UI; no secrets in the bundle
API	FastAPI (Python 3.11), Pydantic, SQLAlchemy 2	REST under /api/v1; OpenAPI at /api/openapi.json; RBAC dependencies on every mutating route
Worker	Separate Python process	jobs table queue (SELECT … FOR UPDATE SKIP LOCKED), DB-stored schedules with locking and stale-job recovery, heartbeat
Database	PostgreSQL 16, Alembic	40 migration files (0001 … 0039); additive, reversible; org_id on every record; append-only audit trigger
Object storage	Storage abstraction: local FS or any S3 API	SeaweedFS (Compose profile), AWS S3, DigitalOcean Spaces, Garage; selected via env
Identity	dev_password (dev/demo), OIDC (Keycloak profile), mTLS header stub	Authorization Code + PKCE, server-side sessions
Optional	ClamAV, HashiCorp Vault, Prometheus / Grafana	Compose profiles

10.1 API design

- JSON over HTTPS, bearer-token authentication, base path /api/v1. Interactive docs at /api/docs.

- Error semantics: 401 unauthenticated or expired session · 403 RBAC denial (audited) · 404 not found or other tenant · 409 state conflict · 413/415/422 upload or validation · 429 rate limited with Retry-After.
- Long-running work (ingest, policy analysis, TR generation and analysis, inventory checks) returns 202 with a job id.
- Appendix A summarises the endpoint groups from the live OpenAPI specification.

10.2 Multi-tenancy

Every record carries org_id. Queries are scoped to the caller's organization and to their system role assignments. Objects addressed by id (workbooks, rows, evidence, discrepancies) resolve their owning system, and requests across tenants return 404. Automated tests check that a user of tenant B gets 403/404 or empty results for tenant A's systems, POA&Ms, findings, search, audit, TR and inventory objects. Each sandbox is its own tenant and is purged after a configurable inactivity period.

11 Security and compliance posture

Area	Implementation
Authentication	AUTH_PROVIDERS: dev_password (simulated, dev only, disabled in production compose), oidc (Code + PKCE S256, state + nonce, JWKS signature, iss/aud/exp checks), mtls_header (trusted-proxy stub for CAC/PIV front-ends)
Sessions	Server-side sessions; idle 30 min, absolute 12 h; rotating hashed refresh tokens; logout revokes; lockout 5 failures / 15 min
Authorization	RBAC scoped to org/system; every mutating route declares a permission dependency (enforced by test); denials audited
Separation of duties	Self-approval blocked; SCA independence; AO-only decisions; Platform Admin has no decision rights; real-user SoD in production
Audit	Hash-chained, append-only audit_events (DB trigger); chain verification; CSV/JSON export; never purged
Web hardening	Strict CSP, nosniff, X-Frame-Options DENY, no-referrer, HSTS; exact-origin CORS allowlist ('*' refused); per-IP rate limits
Uploads	Extension allowlist per kind, magic bytes, size limit, defusedxml, zip-bomb/path-traversal checks, optional ClamAV
Secrets	Env files are parsed as data (never sourced) and validated by check_env; Fernet secret store or Vault KV v2; keys never logged or returned
Production safety	check_env refuses insecure production settings (e.g. AI_PROVIDER=emergent, wildcard CORS, demo login without explicit opt-in)
Supply chain	pip-audit clean on production requirements; Bandit high/medium 0; remaining yarn-audit highs are build-time only (react-scripts)

REQUIRES HUMAN VERIFICATION

OIDC has been tested against a mocked IdP and a dev Keycloak realm. Vault was tested with a mocked client only and ClamAV was not run against a live clamd. FIPS 140-3 operation needs a FIPS-validated OpenSSL provider and host FIPS mode, which have not been set up or validated.

12 Deployment and portability

- **Docker Compose** is the reference deployment: edge proxy, frontend, backend, worker, PostgreSQL, object storage, optional Keycloak, ClamAV, Vault and monitoring profiles.
- **DigitalOcean reference** (docs/DIGITALOCEAN_DEPLOYMENT.md): measured sizing, Ubuntu 24.04 set-up, block-storage volumes, TLS with automatic certificates, a one-command deploy script with fail-fast preflight checks, environment templates, lifecycle procedures, and migration paths to Managed PostgreSQL and other storage profiles with no code change.
- **Demo deploy with recovery deferred** (deploy.sh --demo-without-recovery): read-only preflight, rollback snapshot of the env and image tags, demo settings, backup verification, migration, demo smoke test. Any failure restores the previous env and images.
- **Data recovery tooling** (recover.sh): read-only rehearsal on isolated replicas, a plan with a hash that must match at apply time, read-only evidence integrity checks, cutover and rollback.
- **Portability register** (docs/PORTABILITY.md): the only preview-platform dependencies are the Emergent AI adapter (refused outside preview) and pod bootstrap scripts, neither of which is used by Docker deployments.

REQUIRES HUMAN VERIFICATION

The recovery toolkit was built and verified on isolated replicas in the build environment only. It has **not** been run on the customer Droplet. Docker builds and 'compose up --wait' health checks were validated statically (YAML and shellcheck) in development; the first real run is on the target host.

13 Use cases and walkthroughs

13.1 New system to ATO (FIPS 199)

1. ISSO registers the system and its assets; the ISSM assigns key roles (Prepare).
2. ISSO selects SP 800-60 information types; FIPS 199 computes the high-water mark; the AO approves (Categorize).
3. ISSO applies the SP 800-53B Moderate baseline, tailors with justification and sets ODPs (Select).
4. ISSO writes implementation statements (optionally AI-drafted and reviewed), uploads STIG/ACAS results and policies (Implement).
5. SCA assesses controls, approves TR rows with tester and date, and exports the TR workbook (Assess).
6. ISSM endorses the package; the AO grants ATO with an expiry; POA&Ms track residual risk (Authorize).
7. Monitoring flags KEV, CAT I, overdue POA&Ms and stale evidence (Monitor).

13.2 National Security System (CNSSI 1253)

1. Categorize answers 'Is this an NSS?' = Yes, which preselects CNSSI 1253; C/I/A are kept separate (e.g. M-H-L).
2. Select loads the Appendix D trigraph union with page citations; a re-categorization produces an 'N added / M removed' proposal that applies only on Accept.
3. Official overlays are offered with applicability; the Classified overlay requires an explicit 'classified = Yes'.
4. The parameter comparison shows catalog, CNSSI and system values. Adopting a CNSSI value is audited, can be undone and warns about conflicts.
5. When PII is present (Yes or Unknown), the Privacy Overlay prompt shows the 27 privacy controls left to the overlay.

13.3 Continuous monitoring

Scheduled jobs re-evaluate KEV, freshness and deadlines. The Monitor step and the Portfolio surface what needs attention. New scans deduplicate into canonical findings; remediation marks POA&Ms closure-eligible for a human to close.

13.4 eMASS round trip

Export the TR template from eMASS, import it, let IronVision AI propose results, have the SCA approve, export, review the validation report, and import into eMASS. The same applies to the HW/SW list. Final eMASS acceptance requires human verification.

13.5 Policy gap analysis

Upload an organization's policies. The Policy Auditor maps sections and pages to controls, evaluates each assessment objective and CCI, and optionally refines the results with AI using verified quotes

(whole-document reading for policies under ~60k characters, plus an AI check of every xx-1 policy requirement). A requirement is marked not present only after the whole document and a focused second look found nothing; truncated or timed-out AI batches become 'needs manual review', never 'missing'. Gaps become proposed findings that a human confirms or dismisses; the CCI view shows coverage.

13.6 Inventory reconciliation

Import the HW/SW list and scans. The correlation engine links hosts deterministically, sends ambiguous matches (shared IPs, conflicts) to review with optional AI ranking, and lists discrepancies (missing from inventory, no scan, conflicting identifiers, duplicates, stale scans). Each change needs accept and then approval by a different real user.

13.7 Demo and sales sandbox

'Explore demo' opens a shared synthetic workspace that resets nightly. 'Create account' provisions an empty private sandbox with personas, so one person can walk through ISSO → SCA → AO hand-offs, labelled 'Sandbox: same person'.

14 Limitations, known gaps and roadmap

Area	Status today	Roadmap
Live evidence connectors	MOCKED (MockAdapter, labelled)	Real scanner, cloud and ticketing connectors
eMASS REST sync	MOCKED default adapter; REST adapters are stubs	Authorized read/write against eMASS
eMASS / Excel acceptance of exported workbooks	REQUIRES HUMAN VERIFICATION	Confirm in Excel and eMASS
Droplet deployment and data recovery	Built and rehearsed on replicas; not run on the customer Droplet	Operator-run cutover
CNSSI union, PTA defaults, ACCT layering	SME REVIEW REQUIRED	Agency SME sign-off
Agency-specific information types, SP 800-60 descriptions	Not implemented	Load descriptions; agency type editor
Agency overlay control changes	Metadata only	Apply agency overlay deltas
EPSS, email notifications, OSCAL component definitions	Not implemented / disabled	Backlog
Software ↔ asset assignment UI, asset merge	Future	Inventory phase 2
Multi-replica rate limiting / OIDC state	Per-process in memory	Shared store (Redis or proxy)
Frontend build tooling	Create React App (build-time audit findings)	Migrate to Vite
FIPS 140-3, CAC/PIV, FedRAMP, ATO of the tool itself	Not claimed	Customer-specific

15 Glossary

Term	Meaning
ACAS	Assured Compliance Assessment Solution (Tenable-based DoD vulnerability scanning)
ACCT	Accountability control set of the CNSS Privacy Overlay (CNSSI 1253F Att. 6)
AO / AODR	Authorizing Official / AO Designated Representative
AP	Assessment Procedure (eMASS)
ATO / IATT / DATO	Authority to Operate / Interim Authority to Test / Denial of Authority to Operate
CAT I/II/III	STIG severity categories
CCI	Control Correlation Identifier (DISA)
CKL / CKLB	STIG Viewer checklist formats
CNSSI 1253	Committee on National Security Systems Instruction 1253: categorization and control selection for NSS
CRM	Customer Responsibility Matrix
eMASS	Enterprise Mission Assurance Support Service
FIPS 199 / 200	Federal standards for security categorization / minimum security requirements
HW/SW	Hardware/Software list
IL2–IL6	DoD Cloud Computing SRG information impact levels
ISSM / ISSO	Information System Security Manager / Officer
KEV	CISA Known Exploited Vulnerabilities catalog
NSS	National Security System (44 U.S.C. §3552(b)(6))
ODP	Organization-Defined Parameter
OIDC / PKCE	OpenID Connect / Proof Key for Code Exchange
OSCAL	Open Security Controls Assessment Language (NIST)
PII / PIA / PTA	Personally Identifiable Information / Privacy Impact Assessment / Privacy Threshold Analysis
POA&M	Plan of Action and Milestones
RBAC / SoD	Role-Based Access Control / Separation of Duties
RMF	Risk Management Framework (NIST SP 800-37 Rev. 2)
SCA	Security Control Assessor
SCAP / XCCDF	Security Content Automation Protocol / Extensible Configuration Checklist Description Format
SSP	System Security Plan
STIG	Security Technical Implementation Guide (DISA)
TR	Test Result (eMASS workbook)

A API endpoint summary (appendix)

Generated from the live OpenAPI specification (/api/openapi.json): **306 paths, 335 operations**, grouped by the first path segment under /api/v1. Every mutating operation requires a permission (see section 11); only sign-in, demo login, refresh, logout, sign-up, health and the public whitepaper downloads are unauthenticated.

Group	Ops	Examples
admin	11	GET /admin/ai-settings; GET /admin/identity-mappings; GET /admin/policy-feedback/export; GET /admin/security ...
agency-overlays	2	GET /agency-overlays; POST /agency-overlays
ai	2	GET /ai/status; POST /ai/health
attestations	5	GET /attestations/{att_id}/history; POST /attestations/{att_id}/attest; POST /attestations/{att_id}/evidence; POST /attestations/{att_id}/remind ...
audit-events	2	GET /audit-events; GET /audit-events/verify
audit-log	1	GET /audit-log
auth	13	GET /auth/me; GET /auth/oidc/callback; GET /auth/oidc/login; GET /auth/oidc/register ...
authorization-decisions	1	POST /authorization-decisions/test
banner	1	GET /banner
content	3	GET /content/counts; GET /content/stats; GET /content/versions
content-updates	4	GET /content-updates; GET /content-updates/{update_id}; POST /content-updates/register; POST /content-updates/{update_id}/apply
content-versions	2	GET /content-versions/{version_id}/rules; POST /content-versions/{version_id}/preview
controls	4	GET /controls; GET /controls/cci-index; GET /controls/families; GET /controls/{control_id}
crm	1	GET /crm/sample.csv
dashboard	1	GET /dashboard/leadership
decision-rules	2	GET /decision-rules; PUT /decision-rules/{request_type}
demo	2	POST /demo/attestations/{att_id}/expire; POST /demo/evidence/{evidence_id}/collected-at
docs-center	4	GET /docs-center; GET /docs-center/archive.zip; GET /docs-center/{slug}; GET /docs-center/{slug}/download
emass	7	GET /emass/status; POST /emass/changes/{change_id}/request-approval; POST /emass/changes/{change_id}/resolve; POST /emass/changes/{change_id}/submit ...
emass-import-settings	2	GET /emass-import-settings/ai; PUT /emass-import-settings/ai
emass-imports	13	GET /emass-imports; GET /emass-imports/samples/{report_type}; GET /emass-imports/{import_id}; GET /emass-imports/{import_id}/manage ...
evidence	5	GET /evidence/{evidence_id}; GET /evidence/{evidence_id}/download; POST /evidence/{evidence_id}/legal-hold; POST /evidence/{evidence_id}/remove ...

Group	Ops	Examples
findings	8	GET /findings/{finding_id}; GET /findings/{finding_id}/mappings; GET /findings/{finding_id}/poam-match; GET /findings/{finding_id}/score ...
freshness-policies	1	GET /freshness-policies
health	2	GET /health; GET /health/live
import-center	4	GET /import-center/history; GET /import-center/types; POST /import-center/detect; POST /import-center/retry/{kind}/{item_id}
imported-data	3	GET /imported-data/{import_kind}/{import_id}; POST /imported-data/{import_kind}/{import_id}; POST /imported-data/{import_kind}/{import_id}/undo/{op_id}
ingest-runs	3	GET /ingest-runs/{run_id}; GET /ingest-runs/{run_id}/stig; POST /ingest-runs/{run_id}/retry
inventory	4	GET /inventory/exports/{eid}/download; GET /inventory/exports/{eid}/validation-report; POST /inventory/correlations/{cid}; POST /inventory/discrepancies/{did}
jobs	2	GET /jobs; GET /jobs/{job_id}
mapping-review	6	GET /mapping-review; GET /mapping-review/bulk-jobs/{job_id}; POST /mapping-review/bulk-jobs; POST /mapping-review/bulk-jobs/{job_id}/retry ...
mappings	1	POST /mappings/{map_id}/review
me	2	GET /me/preferences; PUT /me/preferences
notification-prefs	2	GET /notification-prefs; PUT /notification-prefs
notifications	2	GET /notifications; POST /notifications/{notification_id}/ack
oscal-exports	1	GET /oscal-exports/{evidence_id}/download
overlays	2	POST /overlays/import-reference; POST /overlays/{overlay_key}/import
poam-match-rules	1	GET /poam-match-rules
poam-milestones	1	PATCH /poam-milestones/{milestone_id}
poams	12	GET /poams; GET /poams/{poam_id}; GET /poams/{poam_id}/risk; PATCH /poams/{poam_id} ...
policies	13	GET /policies; GET /policies/{policy_id}; GET /policies/{policy_id}/mappings/{control_id}/review; GET /policies/{policy_id}/parameters.csv ...
policy-findings	1	POST /policy-findings/{pf_id}/{action}
priority-weights	1	GET /priority-weights
privacy	1	GET /privacy/preview
providers	5	PATCH /providers/{provider_id}; POST /providers; POST /providers/{provider_id}/crm/apply; POST /providers/{provider_id}/crm/preview ...
pta	2	GET /pta/question-sets; POST /pta/question-sets
public	2	GET /public/demo/{name}; GET /public/whitepaper.{ext}
rbac	1	GET /rbac/matrix

Group	Ops	Examples
ready	1	GET /ready
reference	6	GET /reference/frameworks; GET /reference/info-types; GET /reference/registration; GET /reference/rmf ...
review-flags	1	POST /review-flags/{flag_id}/resolve
reviews	3	GET /reviews; GET /reviews/{request_id}; POST /reviews/{request_id}/decisions
risk	2	GET /risk/weights; PUT /risk/weights
sandbox	6	GET /sandbox/samples.zip; GET /sandbox/status; POST /sandbox/act-as; POST /sandbox/demo-data ...
scheduled-jobs	3	GET /scheduled-jobs; POST /scheduled-jobs/{job_id}/run; PUT /scheduled-jobs/{job_id}
search	1	GET /search
source-types	1	GET /source-types
sources	3	PATCH /sources/{source_id}; POST /sources/{source_id}/run; POST /sources/{source_id}/test
systems	123	DELETE /systems/{system_id}/assets/{asset_id}; DELETE /systems/{system_id}/roles/{assignment_id}; GET /systems; GET /systems/{system_id} ...
tr	14	GET /tr/exports/{eid}/download; GET /tr/exports/{eid}/validation-report; GET /tr/lookup; GET /tr/workbooks/{wid} ...